INSTITUTO UNIVERSITÁRIO DE LISBOA

Mestrado em Engenharia Informática

Segurança em Redes e Sistemas de Informação

Autores:

Rodrigo Gorjão, N.º 82972
João Afonso, N.º 97990
João Tendeiro, N.º 129087
Jossivalter Leal, N.º 146851

Data: 17-10-26

Título do trabalho:

Segurança em Camadas para Comunicações IoT Baseadas em MQTT: Revisão Sistemática da Literatura e Proposta de Arquitetura

Docente: Daniel Maximino Caçador

Repositório: `https://github.com/joaoaeafonso/mqtt_secure`

Resumo

O protocolo MQTT tornou-se o padrão *de facto* para a troca de mensagens na Internet das Coisas, mas a sua especificação deixa a segurança quase inteiramente ao critério de quem o implementa. Como todas as mensagens atravessam um *broker*, a proteção do canal com TLS não basta: termina no próprio *broker*, que passa a ver, guardar e reencaminhar todo o conteúdo, e não impede a repetição de mensagens, a injeção por clientes legítimos nem o abuso de uma chave comprometida. Este trabalho apresenta uma revisão sistemática da literatura sobre mecanismos de segurança para comunicações baseadas em MQTT, conduzida segundo um protocolo explícito: perguntas de investigação, critérios PICOC, *strings* de pesquisa com grupos de sinónimos, critérios de inclusão, exclusão e qualidade, leitura em três passagens e formulário de extração de dados. Analisam-se 20 estudos primários publicados entre 2015 e 2026 e cinco revisões relacionadas, classificados numa taxonomia de oito categorias e comparados segundo as propriedades de segurança que garantem. A comparação mostra que a literatura trata sobretudo confidencialidade, autenticação e integridade, mas raramente reporta, em conjunto, a ligação criptográfica da mensagem ao tópico, a validade temporal e a proteção contra repetição, a política do recetor contra a redução do nível de proteção e a restrição dos tópicos em que cada chave pode publicar. Com base nestas lacunas, propõe-se uma arquitetura de segurança em camadas, composta por camadas independentes e comutáveis entre a aplicação e o transporte, que combina defesa no transporte, um envelope fim-a-fim com AES-256-GCM ou Ed25519 e limitação de tráfego antes de qualquer operação criptográfica. Por fim, define-se o objetivo e o plano da segunda parte do projeto: implementar a arquitetura e medir, num dispositivo restrito (Raspberry Pi), o custo de desempenho e os ataques impedidos por cada camada e combinação de camadas, para identificar a configuração que oferece a maior proteção com o menor impacto no desempenho.

Palavras-chave: MQTT; Internet das Coisas; segurança fim-a-fim; cifra autenticada; revisão sistemática da literatura; defesa em profundidade.

Índice

Resumo **i**

Glossário **vi**

1 Introdução **1**
1.1 Contexto . . . 1
1.2 Problema . . . 1
1.3 Objetivos . . . 2
1.4 Contributos . . . 2
1.5 Estrutura do documento . . . 2

2 Enquadramento teórico **2**
2.1 O protocolo MQTT . . . 3
2.2 Segurança nativa do MQTT e dos *brokers* . . . 4
2.3 Primitivas criptográficas . . . 4
2.3.1 Cifra autenticada com dados associados . . . 4
2.3.2 Códigos de autenticação de mensagem . . . 5
2.3.3 Assinaturas digitais Ed25519 . . . 5
2.4 Validade temporal e proteção contra repetição . . . 6
2.5 Limitação de tráfego . . . 6
2.6 Modelo de ameaças . . . 7

3 Metodologia: protocolo da revisão sistemática **7**
3.1 Definição do problema . . . 8
3.2 Perguntas de investigação . . . 8
3.3 Critérios PICOC . . . 9
3.4 *String* de pesquisa . . . 9
3.5 Processo de pesquisa e ferramenta de apoio . . . 10
3.6 Critérios de inclusão e exclusão . . . 10
3.7 Seleção dos estudos e avaliação da qualidade . . . 10
3.8 Extração de dados . . . 11

4 Trabalhos relacionados: revisões existentes **12**
4.1 Revisões analisadas . . . 12
4.2 Comparação . . . 13
4.3 Posicionamento desta revisão . . . 13

5 Resultados da revisão **14**
5.1 Caracterização dos estudos (QE1, QE2) . . . 14
5.2 Taxonomia das soluções (QF2) . . . 15
5.2.1 C1 — Análise de vulnerabilidades e ataques . . . 15
5.2.2 C2 — Autenticação . . . 16

5.2.3 C3 — Autorização e controlo de acesso 16
5.2.4 C4 — Cifra baseada em atributos 16
5.2.5 C5 — Proteção leve fim-a-fim da mensagem 16
5.2.6 C6 — Proteção do *broker* e do transporte 17
5.2.7 C7 — Deteção de intrusões 17
5.2.8 C8 — Privacidade e anonimato 17
5.3 Comparação dos mecanismos (QF3, QF4) 17
5.4 Respostas às perguntas de investigação 19

6 Proposta: arquitetura de segurança em camadas 20
6.1 Princípios de desenho 20
6.2 Arquitetura em camadas 20
6.3 Camada de transporte e *broker* 21
6.4 Envelope fim-a-fim 21
6.5 Ordem de verificação no recetor 22
6.6 Validade temporal e anti-repetição 22
6.7 Restrição chave–tópico 23
6.8 Gestão de chaves 23
6.9 Limitação de tráfego antes da criptografia 24
6.10 Mapeamento entre ameaças e mecanismos 24
6.11 Comparação com os trabalhos relacionados 24
6.12 Limitações conhecidas 25

7 Objetivo e plano da segunda parte do projeto 25
7.1 Perguntas experimentais 26
7.2 Configurações em estudo 26
7.3 Plataforma experimental 26
7.4 Métricas 28
7.5 Critério de escolha da melhor configuração 28
7.6 Procedimento 29
7.7 Hipóteses 29
7.8 Resultados a entregar 30

8 Discussão 30
8.1 Lacunas do estado da arte 30
8.2 Ameaças à validade 31

9 Conclusões e trabalho futuro 31
9.1 Conclusões 31
9.2 Trabalho futuro 32

A *Strings* de pesquisa por base de dados 37

B Extração de dados por estudo 38

Lista de Figuras

1 Arquitetura de publicação/subscrição do MQTT. O TLS protege cada salto em separado e termina no *broker*; só a proteção fim-a-fim da mensagem sobrevive a um *broker* não confiável. 3
2 Processo da revisão sistemática adotado. 8
3 Diagrama de fluxo PRISMA 2020 da seleção dos estudos. 12
4 Número de estudos primários incluídos por ano de publicação ($n = 20$). 15
5 Taxonomia dos estudos incluídos, com o número de estudos por categoria. 15
6 Número de mecanismos que garantem cada propriedade de segurança (siglas como na Tabela 12). 19
7 Arquitetura proposta: camadas entre a aplicação e o transporte, cada uma comutável de forma independente. A saída percorre as camadas de cima para baixo e a entrada de baixo para cima. 21
8 Formato do envelope (inteiros em *big-endian*); o número sob cada campo é o seu tamanho em octetos. 22

Lista de Tabelas

1 Mecanismos de segurança nativos do MQTT e dos *brokers* e respetivas limitações. 4
2 Ameaças ao MQTT segundo a classificação STRIDE e mecanismos que as mitigam. 7
3 Perguntas de investigação. 8
4 Âmbito da revisão segundo os critérios PICOC. 9
5 Grupos de ideias e sinónimos usados na *string* de pesquisa. 9
6 Registos devolvidos pela *string* principal em cada base de dados. 10
7 Critérios de inclusão (CI) e de exclusão (CE). 11
8 Critérios de avaliação da qualidade. 12
9 Formulário de extração de dados e pergunta a que cada campo responde. 13
10 Comparação das revisões relacionadas com a presente revisão. ✓ abordado; ● parcialmente; – não reportado. 14
11 Estudos primários incluídos. Tipo: R revista, C conferência, W *workshop*. Categorias: ver Figura 5. 14
12 Comparação dos estudos que propõem mecanismos. Propriedades: C confidencialidade, I integridade, Au autenticação, Az autorização, V validade temporal, R anti-repetição, NR não repúdio, D disponibilidade/deteção, P privacidade. BnC: funciona com *broker* não confiável. Aval.: E experimental, F formal, S simulação, A analítica. Restr.: avaliado ou desenhado para dispositivos restritos. ✓ garantido; ● parcialmente; ✗ não, por desenho; – não reportado. 18
13 Sequência de verificações de um envelope recebido. 23
14 Distribuição de chaves por papel. 24
15 Ameaças e mecanismos da arquitetura proposta. 24

16 Posicionamento da proposta face aos trabalhos relacionados mais próximos. Siglas e símbolos como na Tabela 12; LT ligação ao tópico; RN política contra a redução do nível de proteção; CT restrição chave–tópico; Com.: camadas comutáveis em tempo de execução. 25
17 Configurações a avaliar. Transporte: TLS 1.3 com autenticação mútua por certificado, palavras-passe, ACL e identificador de cliente ligado ao utilizador. VT validade temporal; R anti-repetição; CT restrição chave–tópico; LT limitação de tráfego antes da criptografia. 27
18 Métricas de custo e de benefício. 28
19 Ameaças à validade da revisão e mitigação. 31
20 Resumo da extração de dados dos estudos incluídos. 38

Glossário

Sigla	Significado
AAD	*Additional Authenticated Data* — dados autenticados mas não cifrados
ABE	*Attribute-Based Encryption* — cifra baseada em atributos
ACL	*Access Control List* — lista de controlo de acessos
AEAD	*Authenticated Encryption with Associated Data* — cifra autenticada com dados associados
AES	*Advanced Encryption Standard*
AugPAKE	*Augmented Password-Authenticated Key Exchange*
CA	*Certificate Authority* — autoridade de certificação
CP-ABE / KP-ABE	ABE com política no criptograma / na chave
CRL	*Certificate Revocation List* — lista de certificados revogados
DoS / DDoS	*(Distributed) Denial of Service* — negação de serviço (distribuída)
ECC	*Elliptic Curve Cryptography* — criptografia de curvas elípticas
Ed25519	Esquema de assinatura EdDSA sobre a curva Edwards25519
GCM / GMAC	*Galois/Counter Mode* / *Galois Message Authentication Code*
HMAC	*Keyed-Hash Message Authentication Code*
IDS	*Intrusion Detection System* — sistema de deteção de intrusões
IoT	*Internet of Things* — Internet das Coisas
MAC	*Message Authentication Code* — código de autenticação de mensagem
MitM	*Man-in-the-Middle* — ataque de intermediário
ML	*Machine Learning* — aprendizagem automática
MQTT	*Message Queuing Telemetry Transport*
MQTT-SN	MQTT para redes de sensores (*Sensor Networks*)
mTLS	TLS mútuo (autenticação do cliente por certificado)
OAuth	*Open Authorization*
PICOC	*Population, Intervention, Comparison, Outcome, Context*
PRISMA	*Preferred Reporting Items for Systematic Reviews and Meta-Analyses*
QoS	*Quality of Service* — nível de garantia de entrega no MQTT
QE / QF / QG	Questão estatística / focada / geral (perguntas de investigação)
RFC	*Request for Comments* (documento normativo do IETF)
RSL	Revisão Sistemática da Literatura
SRSI	Segurança em Redes e Sistemas de Informação
STRIDE	*Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege*
TEE	*Trusted Execution Environment* — ambiente de execução confiável
TLS	*Transport Layer Security*

1 Introdução

1.1 Contexto

A Internet das Coisas (IoT) liga sensores, atuadores e serviços de *back-end* que trocam pequenas mensagens, com frequência e, muitas vezes, a partir de dispositivos com recursos muito limitados. Entre os protocolos da camada de aplicação usados neste domínio [1], o *Message Queuing Telemetry Transport* (MQTT) impôs-se pela sua simplicidade: normalizado pela OASIS nas versões 3.1.1 [2] e 5.0 [3], segue o paradigma publicação/subscrição, no qual os clientes nunca comunicam diretamente uns com os outros. Um *publisher* envia mensagens para um *tópico* (por exemplo, `fabrica/sala1/temperatura`), e um intermediário, o *broker*, entrega-as a todos os clientes cuja subscrição corresponda a esse tópico. Implementações abertas como o Eclipse Mosquitto [4] tornaram o protocolo omnipresente, de casas inteligentes a ambientes industriais e médicos.

1.2 Problema

A especificação do MQTT trata a segurança como responsabilidade da implementação: oferece um campo de nome de utilizador e palavra-passe no pedido de ligação e recomenda o uso de TLS, mas não define proteção da mensagem em si. Daqui resultam três problemas que estruturam este trabalho.

P1. O *broker* é um ponto de confiança total. O TLS protege apenas cada salto cliente–*broker* [5]. No *broker*, as mensagens existem em claro: quem o comprometer, ou qualquer cliente a quem uma lista de controlo de acessos mal configurada permita subscrever o filtro `#`, vê e pode reencaminhar todo o tráfego [6, 7].

P2. Uma mensagem autêntica pode ser repetida ou desviada. Mesmo uma mensagem criptograficamente autêntica pode ser capturada e repetida mais tarde, ou publicada num tópico diferente daquele para que foi criada. A autenticação não impede estes ataques: são precisos, em separado, um carimbo temporal autenticado (validade temporal), números de sequência (anti-repetição) e a ligação criptográfica ao tópico.

P3. Comprometimento de dispositivos. Num parque com milhares de dispositivos, alguns acabarão comprometidos. Se uma chave válida puder publicar em qualquer tópico, um único dispositivo comprometido pode fazer-se passar por todos os outros, e o incidente de botnets como a Mirai [8] mostra a escala que estes ataques podem atingir.

A literatura propõe numerosas soluções parciais, desde esquemas de autenticação e autorização a cifras baseadas em atributos e ambientes de execução confiáveis, mas é difícil perceber que propriedades cada uma garante, que ameaças deixa por tratar e como se combinam. É este o problema que a revisão endereça: *que mecanismos de segurança propõe o estado da arte para comunicações baseadas em MQTT, que propriedades garantem e que lacunas persistem?*

1.3 Objetivos

O1. Conduzir uma revisão sistemática da literatura, segundo um protocolo explícito e reprodutível [9, 10], sobre mecanismos de segurança para o MQTT.

O2. Classificar as soluções encontradas numa taxonomia e compará-las segundo um conjunto comum de propriedades de segurança e de avaliação.

O3. Comparar a presente revisão com as revisões já publicadas sobre o tema.

O4. Identificar as lacunas do estado da arte e, a partir delas, propor uma arquitetura de segurança em camadas, descrita formalmente.

O5. Definir o objetivo e o plano experimental da segunda parte do projeto: medir, num dispositivo restrito (Raspberry Pi), o custo de desempenho e o benefício de segurança de cada camada, para identificar a configuração com a maior proteção e o menor impacto no desempenho.

1.4 Contributos

- Um protocolo de revisão completo (perguntas, PICOC, *strings* por base de dados, critérios de inclusão, exclusão e qualidade, formulário de extração), reutilizável e reprodutível (Secção 3).
- Uma comparação de 20 estudos primários e de 5 revisões relacionadas, com uma matriz de propriedades de segurança (Secções 4 e 5).
- A formalização de mecanismos que a literatura raramente combina: ligação da mensagem ao tópico, janela anti-repetição, política do recetor contra a redução do nível de proteção e restrição chave–tópico (Secção 6).
- Uma arquitetura modular cuja implementação de referência é disponibilizada num repositório público [11], com documentação técnica completa.

1.5 Estrutura do documento

A Secção 2 apresenta os fundamentos: o protocolo MQTT, os seus mecanismos nativos de segurança, as primitivas criptográficas relevantes e o modelo de ameaças. A Secção 3 descreve o protocolo da revisão sistemática. A Secção 4 analisa as revisões já publicadas e justifica a presente. A Secção 5 apresenta os resultados: a caracterização estatística dos estudos, a taxonomia, a comparação detalhada e as respostas às perguntas de investigação. A Secção 6 propõe a arquitetura em camadas e posiciona-a face aos trabalhos relacionados. A Secção 7 define o objetivo e o plano experimental da segunda parte do projeto. A Secção 8 discute as lacunas e as ameaças à validade, e a Secção 9 conclui e aponta o trabalho futuro. Os anexos contêm as *strings* de pesquisa adaptadas a cada base de dados e a extração de dados por estudo.

2 Enquadramento teórico

Esta secção reúne os conceitos necessários para ler a revisão e a proposta: o funcionamento do MQTT, os mecanismos de segurança que o protocolo e os seus *brokers* oferecem nativamente, as

primitivas criptográficas usadas pelas soluções analisadas e o modelo de ameaças que serve de referência à comparação.

2.1 O protocolo MQTT

O MQTT é um protocolo cliente–servidor de publicação/subscrição que funciona sobre um transporte ordenado e fiável, normalmente TCP (porta 1883) ou TLS (porta 8883) [2]. A Figura 1 ilustra os papéis envolvidos. Os clientes não se conhecem entre si: o desacoplamento no espaço, no tempo e na sincronização é precisamente o que torna o protocolo escalável, mas também o que concentra a confiança no *broker*.

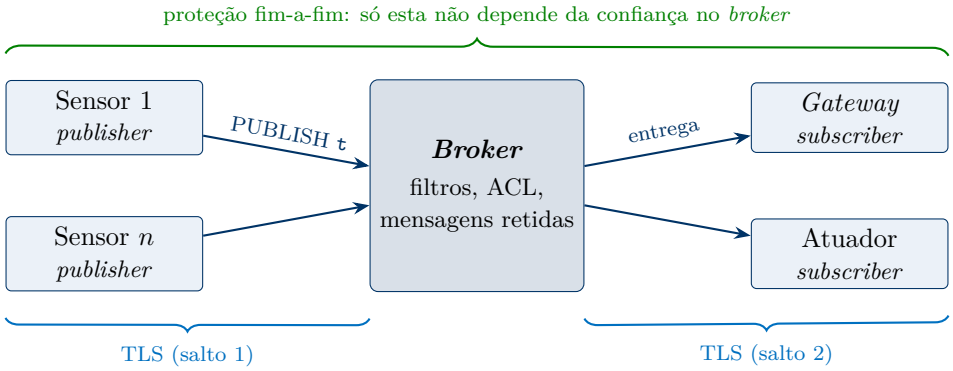


Figura 1. Arquitetura de publicação/subscrição do MQTT. O TLS protege cada salto em separado e termina no *broker*; só a proteção fim-a-fim da mensagem sobrevive a um *broker* não confiável.

Pacotes. O protocolo define catorze tipos de pacote na versão 3.1.1 (CONNECT, CONNACK, PUBLISH, PUBACK, PUBREC, PUBREL, PUBCOMP, SUBSCRIBE, SUBACK, UNSUBSCRIBE, UNSUBACK, PINGREQ, PINGRESP e DISCONNECT), a que a versão 5.0 acrescenta AUTH [3]. Cada pacote tem um cabeçalho fixo de dois a cinco octetos, o que explica a eficiência do protocolo em ligações limitadas.

Tópicos e filtros. Os tópicos são cadeias UTF-8 hierárquicas separadas por `/`. As subscrições usam *filtros* com dois carateres especiais: `+` corresponde a exatamente um nível e `#` a qualquer número de níveis, apenas no fim do filtro. Tópicos começados por `$` (como `$SYS/...`, com estatísticas do *broker*) não são abrangidos por filtros que comecem por um destes carateres. Formalmente, sendo um tópico $\tau = (\tau_1, \ldots, \tau_m)$ e um filtro $f = (f_1, \ldots, f_k)$ sequências de níveis, define-se a correspondência por

$$\mathrm{corr}(f, \tau) \iff \begin{cases} \exists j \le \min(k, m+1) : \; f_j = \texttt{\#} \;\wedge\; \forall i < j : \; f_i \in \{\tau_i, \texttt{+}\}, \\ k = m \;\wedge\; \forall i \le k : \; f_i \in \{\tau_i, \texttt{+}\}, \end{cases} \tag{1}$$

com a restrição adicional de que, se τ_1 começa por `$`, então $f_1 \notin \{\texttt{+}, \texttt{\#}\}$. Esta relação é usada pelas listas de controlo de acessos e, na proposta, pela restrição chave–tópico (Secção 6).

Qualidade de serviço. O MQTT oferece três níveis de entrega: QoS 0 (no máximo uma vez), QoS 1 (pelo menos uma vez, com possíveis duplicados marcados pela *flag* DUP) e QoS 2

(exatamente uma vez, com um protocolo de quatro passos). Note-se que os duplicados legítimos do QoS 1 são indistinguíveis, para um mecanismo anti-repetição, de uma repetição maliciosa — uma tensão que a proposta tem de resolver.

Mensagens retidas e sessões. O *broker* pode reter a última mensagem de cada tópico e entregá-la a novos subscritores, e pode manter sessões persistentes entre ligações. Ambos os mecanismos implicam que o *broker* armazena conteúdo, o que agrava o problema P1.

2.2 Segurança nativa do MQTT e dos *brokers*

A Tabela 1 resume o que o protocolo e os *brokers* comuns oferecem sem extensões.

Tabela 1. Mecanismos de segurança nativos do MQTT e dos *brokers* e respetivas limitações.

Mecanismo	O que oferece	Limitação
Utilizador e palavra-passe (CONNECT)	Autenticação do cliente pelo *broker*	Em claro sem TLS; não autentica mensagens individuais nem o *broker*
TLS 1.2/1.3 [12, 5]	Confidencialidade e integridade de cada salto; autenticação do servidor	Termina no *broker*; custo de estabelecimento em dispositivos restritos [13]; um cliente só controla o seu próprio salto [14]
TLS mútuo (certificado de cliente)	Autenticação forte do cliente; identidade = nome comum do certificado	Exige infraestrutura de chave pública e revogação (CRL)
Listas de controlo de acessos	Autorização por tópico (leitura/escrita) no *broker*	Baseiam-se na identidade declarada se não houver autenticação; não protegem contra o próprio *broker*
Autenticação estendida (AUTH, MQTT 5)	Métodos de desafio–resposta definidos pela aplicação	Só autenticação da ligação; não protege o conteúdo

Nenhum destes mecanismos protege a *mensagem* de ponta a ponta. É neste espaço que se situa a maior parte das propostas da literatura e a arquitetura proposta neste trabalho.

2.3 Primitivas criptográficas

2.3.1 Cifra autenticada com dados associados

Uma cifra AEAD é um par de algoritmos que garante, numa só operação, confidencialidade do texto em claro e integridade e autenticidade tanto do texto como de dados associados que seguem em claro:

$$(C, T) = \mathrm{AEAD.Enc}(K, N, P, A), \tag{2}$$

$$\mathrm{AEAD.Dec}(K, N, C, T, A) = \begin{cases} P & \text{se } T \text{ é válido para } (N, C, A), \\ \bot & \text{caso contrário,} \end{cases} \tag{3}$$

onde K é a chave, N o *nonce*, P o texto em claro, A os dados associados (AAD), C o criptograma e T a etiqueta de autenticação. O facto de A ser autenticado sem ser cifrado é o que permite

ligar criptograficamente a uma mensagem metadados que têm de permanecer legíveis, como o cabeçalho ou o tópico MQTT.

AES-GCM. No modo GCM [15], com chave K e *nonce* de 96 bits, calcula-se a subchave $H = E_K(0^{128})$ e o bloco inicial $J_0 = N \,\|\, 0^{31} \,\|\, 1$. O texto é cifrado em modo contador a partir de $J_0 + 1$ e a etiqueta é

$$T = \mathrm{MSB}_t(\mathrm{GHASH}_H(A \,\|\, 0^v \,\|\, C \,\|\, 0^u \,\|\, [\mathrm{len}(A)]_{64} \,\|\, [\mathrm{len}(C)]_{64}) \oplus E_K(J_0)) \,, \tag{4}$$

onde GHASH_H é uma função polinomial em $\mathrm{GF}(2^{128})$ e u, v completam blocos de 128 bits. Com P vazio obtém-se o GMAC, um código de autenticação de mensagem: $T = \mathrm{AEAD.Enc}(K, N, \varnothing, A)$.

Limite dos *nonces* aleatórios. A segurança do GCM colapsa se o mesmo par (K, N) for usado duas vezes: o XOR dos dois criptogramas revela o XOR dos textos e a subchave H pode ser recuperada, permitindo falsificar etiquetas [16]. Com *nonces* aleatórios de $b = 96$ bits e q mensagens por chave, a probabilidade de colisão é limitada pelo paradoxo do aniversário:

$$\Pr[\text{colisão}] \;\le\; \frac{q(q-1)}{2^{b+1}} \;\approx\; \frac{q^2}{2^{97}}. \tag{5}$$

Para $q = 2^{32}$ a probabilidade é da ordem de 2^{-33}, razão pela qual o NIST limita a 2^{32} o número de invocações por chave com *nonces* aleatórios [15]. Esquemas de longa duração precisam, por isso, de rotação de chaves.

ChaCha20-Poly1305. Alternativa sem dependência de instruções AES em *hardware*, com chave de 256 bits, *nonce* de 96 bits e etiqueta de 128 bits [17]; é a escolha de [18] para nós restritos.

2.3.2 Códigos de autenticação de mensagem

O HMAC [19] constrói um MAC a partir de uma função de *hash* $\mathcal{H}$:

$$\mathrm{HMAC}(K, m) = \mathcal{H}\big((K' \oplus \mathit{opad}) \,\|\, \mathcal{H}((K' \oplus \mathit{ipad}) \,\|\, m)\big), \tag{6}$$

onde K' é a chave ajustada ao tamanho do bloco. Um MAC dá integridade e autenticidade face a quem não conhece K, mas *não* prova a origem perante terceiros: qualquer detentor de K (incluindo o recetor) pode produzir a mesma etiqueta.

2.3.3 Assinaturas digitais Ed25519

O Ed25519 [20, 21] é um esquema de assinatura sobre a curva de Edwards equivalente à Curve25519, com ponto base B de ordem prima ℓ. A partir da chave privada (32 octetos) derivam-se o escalar s e a chave pública $A = [s]B$. Para assinar M:

$$r = \mathcal{H}(\mathit{prefixo} \,\|\, M) \bmod \ell, \quad R = [r]B, \quad k = \mathcal{H}(R \,\|\, A \,\|\, M) \bmod \ell, \quad S = (r + k\,s) \bmod \ell, \tag{7}$$

e a assinatura é (R, S), com 64 octetos. A verificação aceita sse

$$[8][S]B = [8]R + [8][k]A. \tag{8}$$

Como r é derivado deterministicamente da chave e da mensagem, o esquema elimina a dependência de um gerador aleatório no momento da assinatura. Ao contrário de um MAC, só o detentor de s consegue assinar, enquanto qualquer detentor de A consegue verificar: a assinatura dá *prova de origem* (não repúdio).

2.4 Validade temporal e proteção contra repetição

Janela temporal. Uma mensagem tem *validade temporal* se foi produzida há pouco tempo, segundo um carimbo temporal autenticado pelo remetente. Dada uma mensagem com carimbo temporal t_m, recebida no instante t, um recetor com tolerância de idade Δ_a e de desvio de relógio Δ_s aceita-a sse

$$t - \Delta_a \;\le\; t_m \;\le\; t + \Delta_s. \tag{9}$$

A validade temporal responde à pergunta «esta mensagem é recente?» e limita o tempo durante o qual uma mensagem capturada é útil, mas *não* responde a «esta mensagem já foi recebida?»: não impede a repetição dentro da janela Δ_a. É esse o papel do mecanismo seguinte.

Janela deslizante de números de sequência. O mecanismo anti-repetição do IPsec ESP [22] mantém, por remetente, o maior número de sequência aceite h e um mapa de bits $W \in \{0,1\}^w$ (com $w = 64$ o valor recomendado), em que $W_i = 1$ significa que $h - i$ já foi recebido. Para uma mensagem autêntica com número $s > 0$:

$$\text{aceita}(s) \iff \begin{cases} s > h, & \text{e então } W \leftarrow (W \ll (s-h)) \mid 1, \quad h \leftarrow s; \\ 0 \le h - s < w \;\wedge\; W_{h-s} = 0, & \text{e então } W_{h-s} \leftarrow 1; \\ \text{falso}, & \text{se } h - s \ge w \text{ ou } W_{h-s} = 1. \end{cases} \tag{10}$$

O mecanismo tolera reordenação até w posições e rejeita duplicados e mensagens antigas. Duas condições são essenciais: o estado só pode ser atualizado *depois* de verificada a autenticidade (caso contrário um atacante avança a janela com números forjados), e cada chave deve pertencer a um único remetente.

2.5 Limitação de tráfego

O balde de testemunhos (*token bucket*) limita a taxa média a ρ mensagens por segundo, com rajadas até β. O número de testemunhos disponível no instante t, dado o estado no último acesso t_0, é

$$b(t) = \min\big(\beta,\; b(t_0) + \rho\,(t - t_0)\big), \tag{11}$$

e uma mensagem é aceite sse $b(t) \ge 1$, caso em que $b \leftarrow b(t) - 1$. Num intervalo de duração Δ, o número de mensagens aceites é limitado por $\beta + \rho\,\Delta$, independentemente da taxa oferecida.

2.6 Modelo de ameaças

Considera-se um adversário que pode (i) observar e alterar o tráfego na rede, (ii) ligar-se ao *broker* como cliente, subscrever, publicar e repetir mensagens, (iii) reivindicar a identidade de outro cliente, (iv) comprometer o próprio *broker* ou (v) comprometer um dispositivo legítimo, obtendo as suas chaves. A Tabela 2 organiza as ameaças segundo as categorias STRIDE, que correspondem às classes de problemas identificadas para o MQTT em [23].

Tabela 2. Ameaças ao MQTT segundo a classificação STRIDE e mecanismos que as mitigam.

Categoria	Ameaça no MQTT	Mitigação típica
Spoofing	Cliente reivindica a identidade de outro; mensagens injetadas em tópicos alheios	Autenticação (palavras-passe, mTLS); autenticação da mensagem; restrição chave–tópico
Tampering	Alteração do conteúdo, do cabeçalho ou do tópico em trânsito ou no *broker*	TLS (por salto); AEAD/MAC/assinatura com tópico nos dados associados (fim-a-fim)
Repudiation	Remetente nega ter enviado; recetor fabrica mensagens em nome do remetente	Assinaturas digitais (um MAC partilhado não basta)
Information disclosure	Subscrição de `#`; *broker* curioso; tópicos `$SYS`	ACL; cifra fim-a-fim; TEE no *broker* [7]
Denial of service	Inundação de mensagens; ligações lentas [24]; esgotamento de estado	Limitação de tráfego; limites de pacotes e ligações; estado limitado; IDS [25]
Elevation of privilege	Abuso de ACL baseadas em identidade não verificada; chave de um dispositivo usada para outros	ACL com identidade autenticada; restrição chave–tópico; revogação

Defesa em profundidade. Se um ataque tiver de ultrapassar n camadas de defesa independentes, cada uma contornável com probabilidade p_i, a probabilidade de sucesso é

$$P_{\text{sucesso}} = \prod_{i=1}^{n} p_i, \tag{12}$$

estritamente menor do que a de qualquer camada isolada sempre que $p_i < 1$. A hipótese de independência raramente se verifica por inteiro (por exemplo, o roubo de uma chave de dispositivo pode afetar várias camadas), mas o modelo justifica a combinação de mecanismos em camadas distintas: transporte, mensagem e disponibilidade.

3 Metodologia: protocolo da revisão sistemática

A revisão segue as diretrizes de Kitchenham e Charters para revisões sistemáticas em engenharia de *software* [9], organizadas em três fases (planeamento, condução e relato), e relata a seleção de estudos com o diagrama de fluxo PRISMA 2020 [10]. A Figura 2 resume o processo; as subsecções seguintes descrevem cada passo.

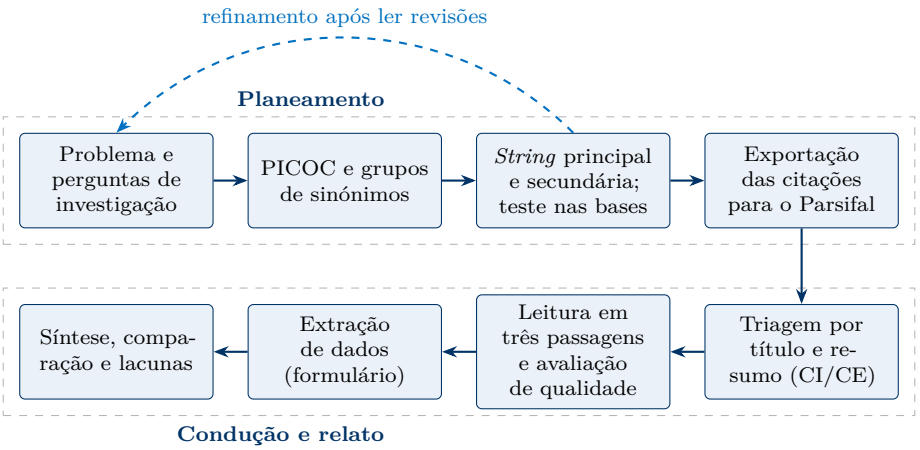


Figura 2. Processo da revisão sistemática adotado.

3.1 Definição do problema

O problema que a revisão procura esclarecer foi enunciado na Secção 1: a especificação do MQTT deixa a proteção das mensagens à implementação, o TLS termina no *broker*, e a autenticação isolada não impede a repetição, a mudança de tópico nem o abuso de uma chave comprometida. Pretende-se identificar as melhores soluções do estado da arte académico atual para este problema, as propriedades que garantem e as lacunas que deixam.

3.2 Perguntas de investigação

As perguntas organizam-se em três grupos (Tabela 3): uma pergunta geral, que define *o que* se investiga; perguntas focadas, que procuram *como* os problemas são tratados; e perguntas estatísticas, que quantificam *quanto* é feito.

Tabela 3. Perguntas de investigação.

ID	Pergunta	Motivação
QG	Que mecanismos de segurança são propostos na literatura para proteger comunicações IoT baseadas em MQTT e que propriedades de segurança garantem?	Delimitar o estado da arte
QF1	Que ameaças e vulnerabilidades do MQTT são identificadas e como são demonstradas?	Modelo de ameaças de referência
QF2	Que mecanismos são propostos e em que ponto da arquitetura atuam (transporte, *broker*, mensagem fim-a-fim, deteção)?	Taxonomia das soluções
QF3	Que propriedades garantem (confidencialidade, integridade, autenticação, autorização, validade temporal, anti-repetição, não repúdio, disponibilidade, privacidade) e assumem um *broker* confiável?	Base da comparação
QF4	Como são avaliadas as soluções (protótipo, plataforma, métricas, verificação formal, dispositivos restritos)?	Maturidade da evidência
QF5	Que limitações e desafios em aberto são reportados?	Lacunas e trabalho futuro
QE1	Quantas publicações existem por ano?	Evolução do interesse
QE2	Qual a distribuição por tipo de publicação (revista, conferência, *workshop*)?	Maturidade da área
QE3	Quantos estudos abordam cada categoria e cada propriedade de segurança?	Identificar áreas pouco exploradas

3.3 Critérios PICOC

A Tabela 4 delimita o âmbito da revisão segundo os critérios PICOC.

Tabela 4. Âmbito da revisão segundo os critérios PICOC.

Critério	Definição nesta revisão
Population	Comunicações IoT baseadas em MQTT ou MQTT-SN: clientes (sensores, atuadores, *gateways*) e *brokers*.
Intervention	Mecanismos de segurança: criptográficos (cifra, MAC, assinaturas, acordo de chaves), de autenticação e autorização, de proteção do *broker*, de deteção de ataques e de privacidade.
Comparison	MQTT com a segurança nativa (palavra-passe, ACL) ou apenas com TLS; comparação entre os mecanismos propostos.
Outcome	Propriedades de segurança garantidas, ameaças mitigadas, custo (latência, memória, energia, débito) e tipo de avaliação.
Context	Investigação académica com revisão por pares, publicada entre 2014 (normalização do MQTT 3.1.1 pela OASIS) e 2026, em ambientes IoT residenciais, industriais e de saúde.

3.4 *String* de pesquisa

Grupos de ideias e sinónimos. A partir das perguntas identificaram-se três grupos de ideias gerais, a cada um dos quais se associaram sinónimos (Tabela 5). Os termos de um grupo combinam-se com `OR` e os grupos entre si com `AND`.

Tabela 5. Grupos de ideias e sinónimos usados na *string* de pesquisa.

Grupo	Termos (combinados com OR)
G1 — Protocolo	`"MQTT"`, `"MQTT-SN"`, `"MQ Telemetry Transport"`, `"Message Queuing Telemetry Transport"`, `"Message Queue Telemetry Transport"`
G2 — Segurança	`"security"`, `"secure"`, `"authentication"`, `"authorization"`, `"access control"`, `"encryption"`, `"confidentiality"`, `"integrity"`, `"privacy"`, `"attack*"`, `"vulnerabilit*"`, `"intrusion"`
G3 — Domínio	`"Internet of Things"`, `"IoT"`, `"IIoT"`, `"publish/subscribe"`, `"publish-subscribe"`, `"machine-to-machine"`, `"M2M"`
G4 — Revisões (só na secundária)	`"systematic literature"`, `"systematic review"`, `"literature review"`, `"survey"`

***String* principal.** A combinação dos grupos G1, G2 e G3, aplicada ao título, resumo e palavras-chave, é:

```
("MQTT"OR "MQTT-SN"OR "MQ Telemetry Transport"OR "Message Queuing Telemetry
Transport"OR "Message Queue Telemetry Transport")
AND ("security"OR "secure"OR "authentication"OR "authorization"OR "access
control"OR "encryption"OR "confidentiality"OR "integrity"OR "privacy"OR
"attack*"OR "vulnerabilit*"OR "intrusion")
AND ("Internet of Things"OR "IoT"OR "IIoT"OR "publish/subscribe"OR
"publish-subscribe"OR "machine-to-machine"OR "M2M")
```

***String* secundária.** Acrescentando o grupo G4 com mais um `AND`, obtém-se a *string* secundária, usada para encontrar revisões já publicadas sobre o tema. O termo `"survey"` foi acrescentado aos três propostos no protocolo base porque, nesta área, as revisões são publicadas maioritariamente com esse título (por exemplo, [26, 27]). A leitura das revisões assim encontradas (Secção 4) levou a dois refinamentos: inclusão de `"MQTT-SN"` e de `"intrusion"` na *string* principal, já que várias soluções visam a variante para redes de sensores [28, 18] e a deteção de intrusões é uma linha de investigação própria [25, 29]; e separação explícita das perguntas QF3 (propriedades) e QF4 (avaliação).

Bases de dados. Foram selecionadas as bases que indexam as principais revistas e conferências de segurança e redes: IEEE Xplore, Scopus, ACM Digital Library, Web of Science e ScienceDirect. A adaptação da *string* à sintaxe de cada uma consta do Anexo A. O teste revelou limitações que obrigaram a adaptações: o ScienceDirect não suporta o carácter universal `*` e limita o número de operadores booleanos por campo, pelo que os termos truncados foram substituídos pelas formas singular e plural e a *string* foi dividida em consultas parciais; o IEEE Xplore limita o número de termos por pesquisa, pelo que se pesquisou nos metadados (título, resumo e palavras-chave) com os grupos completos. A Tabela 6 regista o número de registos devolvidos por cada base, executadas as pesquisas em [dd-mm-aaaa].

Tabela 6. Registos devolvidos pela *string* principal em cada base de dados.

Base de dados	Registos
IEEE Xplore	[n]
Scopus	[n]
ACM Digital Library	[n]
Web of Science	[n]
ScienceDirect	[n]
Total	[n]

3.5 Processo de pesquisa e ferramenta de apoio

As citações de todos os registos foram exportadas de cada base (formato BibTeX ou RIS) e importadas na ferramenta Parsifal, que remove duplicados e suporta a triagem, a avaliação de qualidade e a extração de dados por formulário, exportando no fim os dados extraídos em CSV.

3.6 Critérios de inclusão e exclusão

Um estudo é incluído se satisfizer *todos* os critérios de inclusão e *nenhum* dos de exclusão (Tabela 7).

Por aplicação do CE2, a versão em conferência do protocolo baseado em AugPAKE [30] foi excluída em favor da sua versão alargada em revista, o MQTT-Auth [31].

3.7 Seleção dos estudos e avaliação da qualidade

Primeira fase: título e resumo. Removidos os duplicados, cada registo foi classificado por dois revisores de forma independente, lendo apenas o título e o resumo, segundo os critérios da

Tabela 7. Critérios de inclusão (CI) e de exclusão (CE).

ID	Critério
CI1	Propõe, implementa ou avalia um mecanismo de segurança para MQTT ou MQTT-SN, ou analisa ameaças e vulnerabilidades específicas do MQTT.
CI2	É um estudo primário publicado em revista, conferência ou *workshop* com revisão por pares.
CI3	Foi publicado entre 2014 e 2026.
CI4	O texto integral está acessível e escrito em inglês ou português.
CE1	O MQTT é apenas mencionado ou usado como transporte, sem contributo de segurança.
CE2	É uma versão preliminar de outro estudo incluído com o mesmo contributo (mantém-se a versão mais completa).
CE3	É literatura cinzenta: tese, relatório técnico, patente, apresentação ou artigo sem revisão por pares.
CE4	É uma revisão ou inquérito (analisado à parte como estudo secundário, Secção 4).
CE5	Tem menos de quatro páginas ou não descreve o mecanismo com detalhe suficiente para ser avaliado.
CE6	Trata exclusivamente de outro protocolo (CoAP, AMQP, DDS) sem resultados para o MQTT.

Tabela 7. A concordância entre revisores foi medida com o coeficiente kappa de Cohen [32],

$$\kappa = \frac{p_o - p_e}{1 - p_e}, \qquad p_e = \sum_{c \in \{\text{inc},\text{exc}\}} \frac{n_{1c}}{N} \cdot \frac{n_{2c}}{N}, \tag{13}$$

onde p_o é a proporção de decisões coincidentes, p_e a concordância esperada por acaso, N o número de registos e n_{rc} o número de registos que o revisor r classificou na classe c. Obteve-se $\kappa = \mathbf{[0{,}00]}$; as divergências foram resolvidas por discussão.

Segunda fase: leitura em três passagens. Os estudos que passaram a primeira fase foram lidos segundo o método de Keshav [33]: a primeira passagem (título, resumo, introdução, títulos das secções e conclusões) confirma a categoria e a relevância; a segunda (texto completo, figuras e tabelas, ignorando demonstrações) permite reaplicar os critérios e avaliar a qualidade; a terceira, reservada aos estudos incluídos, reconstrói mentalmente o trabalho e alimenta a extração de dados.

Avaliação da qualidade. Cada estudo foi pontuado nos cinco critérios da Tabela 8, com $q_{ij} \in \{0;\ 0{,}5;\ 1\}$ (não, em parte, sim). A pontuação do estudo i é

$$Q_i = \sum_{j=1}^{5} q_{ij}, \qquad 0 \le Q_i \le 5, \tag{14}$$

e foram excluídos os estudos com $Q_i < 2{,}5$.

Fluxo de seleção. A Figura 3 apresenta o diagrama PRISMA 2020 do processo.

3.8 Extração de dados

Para responder às perguntas de investigação definiu-se o formulário de extração da Tabela 9, preenchido no Parsifal para cada estudo incluído durante a terceira passagem de leitura. O resumo da extração consta do Anexo B.

Tabela 8. Critérios de avaliação da qualidade.

ID	Pergunta
QA1	O objetivo e o contributo estão claramente definidos?
QA2	O modelo de ameaças ou as propriedades de segurança pretendidas são explícitos?
QA3	O mecanismo (ou a análise) está descrito com detalhe suficiente para ser reproduzido?
QA4	Há avaliação experimental, analítica ou formal dos resultados?
QA5	As limitações e os custos são discutidos?

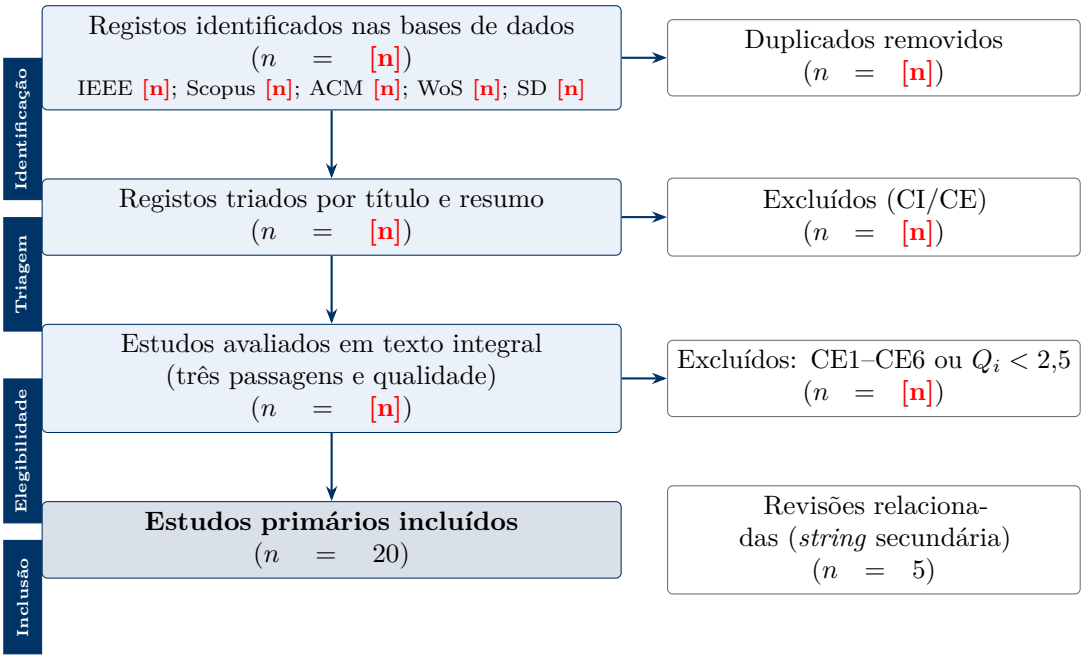


Figura 3. Diagrama de fluxo PRISMA 2020 da seleção dos estudos.

4 Trabalhos relacionados: revisões existentes

A *string* secundária devolveu [n] registos, dos quais foram selecionadas para leitura as 5 revisões mais diretamente relacionadas com a segurança do MQTT. Esta secção resume-as, compara-as entre si e com a presente revisão (Tabela 10) e justifica a necessidade de uma nova revisão.

4.1 Revisões analisadas

Perrone et al. (2017) [26]. Escrito na sequência dos ataques DDoS da botnet Mirai, analisa o MQTT enquanto protocolo concebido para dispositivos de baixa capacidade e descreve as soluções e melhorias de segurança habitualmente sugeridas e aplicadas em instalações reais. Os próprios autores caracterizam o levantamento de temas de investigação como «conciso, embora não exaustivo».

Nebbione e Calzarossa (2020) [34]. Revisão abrangente da segurança dos protocolos da camada de aplicação da IoT, tanto de troca de mensagens (onde se inclui o MQTT) como de descoberta de serviços. Analisa as principais ameaças e as vulnerabilidades publicadas (CVE) de produtos e serviços, e boas práticas de mitigação. Conclui que a falta de serviços de segurança nos próprios protocolos, os erros de configuração e as limitações dos dispositivos tornam a segurança

Tabela 9. Formulário de extração de dados e pergunta a que cada campo responde.

Campo	Valores	Pergunta
Ano; tipo de publicação	ano; revista / conferência / *workshop*	QE1, QE2
Tipo de contributo	análise de ameaças / mecanismo / avaliação / conjunto de dados	QF1, QF2
Categoria	uma das oito categorias da taxonomia (Secção 5.2)	QF2, QE3
Ponto de atuação	transporte / *broker* / mensagem fim-a-fim / deteção	QF2
Primitivas	AES, ChaCha20-Poly1305, HMAC, ABE, ECC, RSA, PAKE, TEE, ML…	QF2
Propriedades	C, I, Au, Az, V, R, NR, D, P (ver Tabela 12)	QF3, QE3
Confiança no *broker*	total / parcial / nenhuma	QF3
Avaliação	protótipo, plataforma, métricas, verificação formal	QF4
Dispositivos restritos	sim / não	QF4
Limitações declaradas	texto livre	QF5

na camada de aplicação particularmente difícil.

Hintaw et al. (2023) [23]. Centrado no MQTT, organiza os problemas de segurança decorrentes do desenho do protocolo em negação de serviço, falsificação de identidade, divulgação de informação, elevação de privilégios e adulteração de dados, provocados por atacantes internos e externos, e revê as técnicas propostas para os tratar. Destaca como desafio em aberto o custo de processamento que a segurança acrescenta a dispositivos alimentados por bateria.

Lakshminarayana et al. (2024) [27]. Publicado na *IEEE Communications Surveys & Tutorials*, propõe uma classificação das vulnerabilidades do MQTT, categoriza os ataques segundo as características que explicam a sua execução e discute em detalhe os mecanismos de defesa, com ênfase em técnicas de identificação de vulnerabilidades e de deteção e prevenção de ataques, terminando com lições aprendidas e direções de investigação.

Laghari et al. (2024) [35]. Analisa a segurança do «ecossistema» MQTT — ataques prevalentes, consequências, estratégias de mitigação e investigação futura — e apresenta uma taxonomia de ataques. Os autores apontam às revisões anteriores uma discussão ampla mas superficial dos ataques e contramedidas e a omissão de componentes e papéis relevantes na construção de aplicações MQTT.

4.2 Comparação

A Tabela 10 compara as revisões segundo o âmbito, o tipo de análise e o que oferecem para lá do levantamento. As células assinaladas com – correspondem a aspetos que a revisão não reporta.

4.3 Posicionamento desta revisão

As revisões existentes estão organizadas sobretudo em torno dos *ataques*: classificam vulnerabilidades e associam-lhes contramedidas. Esta revisão distingue-se em quatro pontos:

1. **Protocolo explícito e reprodutível.** Perguntas de investigação, PICOC, *strings* por base de dados, critérios de inclusão, exclusão e qualidade, concordância entre revisores e diagrama

Tabela 10. Comparação das revisões relacionadas com a presente revisão. ✓ abordado; ● parcialmente; – não reportado.

Revisão	Ano	Só MQTT	Taxonomia de ataques	Revê defesas	Compara por propriedade	Protocolo RSL explícito	Propõe arquitetura
Perrone et al. [26]	2017	✓	–	✓	–	–	–
Nebbione e Calzarossa [34]	2020	●	✓	✓	–	–	–
Hintaw et al. [23]	2023	✓	✓	✓	–	–	–
Lakshminarayana et al. [27]	2024	✓	✓	✓	–	–	–
Laghari et al. [35]	2024	✓	✓	✓	–	–	–
Este trabalho	2026	✓	●	✓	✓	✓	✓

PRISMA são relatados (Secção 3), o que permite repetir e atualizar a revisão.

2. **Comparação por propriedade de segurança.** Os estudos são comparados segundo as propriedades que garantem à *mensagem* — incluindo validade temporal, anti-repetição e não repúdio — e segundo a confiança que depositam no *broker*, e não apenas segundo os ataques que mitigam (Secção 5.3).

3. **Cobertura atualizada**, até 2026, incluindo trabalhos sobre anonimato [36], deteção distribuída de intrusões [29] e autenticação sem certificados [37].

4. **Ligação a uma proposta concreta.** As lacunas identificadas fundamentam uma arquitetura (Secção 6) cuja implementação de referência está disponível publicamente [11].

5 Resultados da revisão

A Tabela 11 identifica os 20 estudos primários incluídos, numerados por ordem cronológica (E01–E20), com o tipo de publicação e a categoria que lhes foi atribuída na taxonomia da Secção 5.2.

Tabela 11. Estudos primários incluídos. Tipo: R revista, C conferência, W *workshop*. Categorias: ver Figura 5.

ID	Estudo	Ano	Tipo	Cat.	ID	Estudo	Ano	Tipo	Cat.
E01	Singh et al. [28]	2015	C	C4	E11	Vaccari et al. [24]	2020	R	C1
E02	Niruntasukrat et al. [38]	2016	W	C3	E12	Vaccari et al. [25]	2020	R	C7
E03	Rizzardi et al. [39]	2016	R	C3	E13	Segarra et al. [7]	2020	C	C6
E04	Andy et al. [6]	2017	C	C1	E14	Dahlmanns et al. [40]	2021	W	C5
E05	Calabretta et al. [31]	2018	R	C3	E15	Spielvogel et al. [14]	2021	W	C6
E06	Hernández Ramos et al. [41]	2018	R	C1	E16	Prantl et al. [13]	2021	C	C6
E07	Dinculeană e Cheng [42]	2019	R	C5	E17	Van Glabbeek et al. [43]	2022	R	C5
E08	Lohachab e Karambir [44]	2019	R	C2	E18	Buccafurri et al. [36]	2023	R	C8
E09	Malina et al. [45]	2019	C	C5	E19	Alotaibi et al. [29]	2024	R	C7
E10	Sadio et al. [18]	2019	C	C5	E20	Javadi et al. [37]	2026	R	C2

5.1 Caracterização dos estudos (QE1, QE2)

Publicações por ano (QE1). A Figura 4 mostra a distribuição temporal. O interesse surge logo após a normalização do MQTT 3.1.1 (2014) e atinge o máximo entre 2016 e 2021, período

em que se concentram $2+1+2+4+3+3=15$ dos 20 estudos (75,0 %), com o pico em 2019. A partir de 2022 o número de estudos incluídos por ano diminui, mas os trabalhos mais recentes deslocam-se de mecanismos básicos de autenticação para problemas mais específicos: segurança muitos-para-muitos, anonimato, deteção distribuída e autenticação sem certificados.

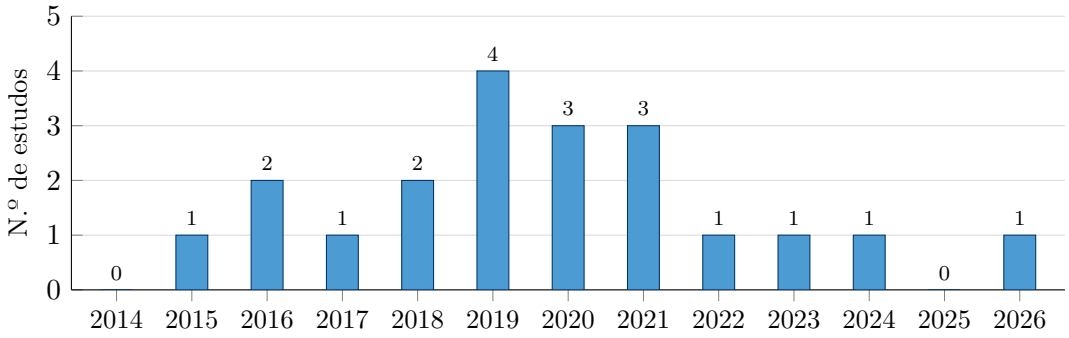


Figura 4. Número de estudos primários incluídos por ano de publicação ($n = 20$).

Tipo de publicação (QE2). Onze estudos (55,0 %) foram publicados em revistas, seis (30,0 %) em conferências e três (15,0 %) em *workshops*. A proporção de revistas cresce ligeiramente ao longo do período: dos dez estudos publicados desde 2020, seis (60 %) são artigos de revista, contra cinco dos dez anteriores (50 %).

5.2 Taxonomia das soluções (QF2)

Os estudos foram agrupados em oito categorias segundo o *ponto de atuação* do mecanismo e o *objetivo* principal (Figura 5). Cada estudo foi atribuído à categoria do seu contributo principal.

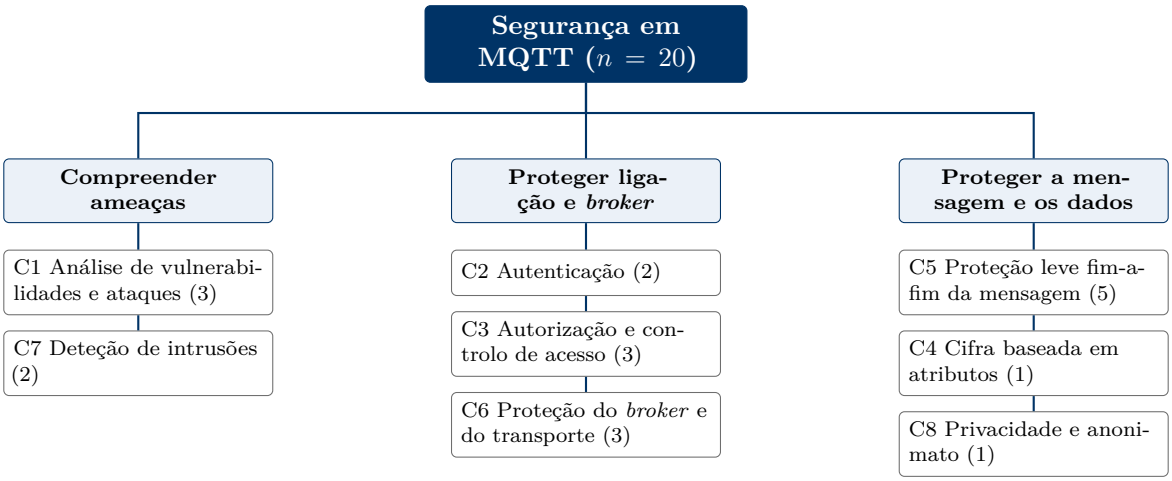


Figura 5. Taxonomia dos estudos incluídos, com o número de estudos por categoria.

5.2.1 C1 — Análise de vulnerabilidades e ataques

Estes estudos fundamentam o modelo de ameaças. Andy et al. [6] observam que, por omissão, o MQTT só oferece autenticação e não cifra os dados em trânsito, e demonstram cenários de ataque que comprometem a privacidade, a autenticação e a integridade. Hernández Ramos et al. [41]

propõem uma técnica de *fuzzing* baseada em modelos para testar implementações do protocolo. Vaccari et al. [24] identificam uma fraqueza que permite ao cliente configurar o comportamento do servidor e exploram-na no SlowITe, um ataque de negação de serviço de baixa taxa, eficaz contra serviços reais com e sem cifra e com poucos recursos do atacante. Em conjunto, estes trabalhos mostram que as ameaças relevantes vão da escuta e injeção triviais em *brokers* mal configurados até à negação de serviço por ligações lentas, que nem a cifra evita.

5.2.2 C2 — Autenticação

Lohachab e Karambir [44] apresentam um esquema leve de autenticação e autorização entre dispositivos, baseado em ECC e MQTT, implementado e comparado com outros esquemas. Javadi et al. [37] propõem o CMAP, um protocolo de autenticação mútua sem certificados nem autoridade de certificação, sobre curvas elípticas, que preserva confidencialidade e integridade; o protocolo é verificado formalmente, avaliado em Raspberry Pi com o *broker* Mosquitto (338 ms de latência de autenticação contra 713 ms com TLS) e simulado em NS-3 com nós fixos e móveis.

5.2.3 C3 — Autorização e controlo de acesso

Niruntasukrat et al. [38] adaptam o OAuth 1.0a ao MQTT, tendo em conta os recursos limitados dos nós, a ausência de interface de utilizador e a distribuição de chaves, e mostram atrasos de autorização e *overhead* mínimos numa plataforma real. Rizzardi et al. [39] estendem o MQTT com um enquadramento de gestão de chaves e outro de aplicação de políticas (AUPS, disponível em código aberto). Calabretta et al. [31] propõem o MQTT-Auth: o AugPAKE (um acordo de chaves autenticado por palavra-passe) garante a confidencialidade e dois *tokens* autenticam a utilização de um tópico e autorizam o acesso a ele, com extensão a hierarquias de tópicos (versão alargada de [30]).

5.2.4 C4 — Cifra baseada em atributos

Singh et al. [28] propõem o SMQTT e o SMQTT-SN, que acrescentam ao MQTT cifra baseada em atributos com política na chave ou no criptograma (KP/CP-ABE) sobre ECC leve: o *publisher* cifra para um conjunto de atributos e só os subscritores com atributos compatíveis decifram. A ABE resolve elegantemente a confidencialidade de grupo (um criptograma, vários destinatários), mas tem um custo computacional elevado para dispositivos restritos.

5.2.5 C5 — Proteção leve fim-a-fim da mensagem

É a categoria mais numerosa. Dinculeană e Cheng [42] propõem o mapeamento *Value-to-HMAC*, que envia valores sob a forma de HMAC em vez de os cifrar, garantindo confidencialidade e integridade com um único mecanismo e com melhor desempenho do que uma cifra simétrica. Malina et al. [45] propõem três níveis de segurança: mensagens não adulteradas, proteção da privacidade das fontes e dos recetores, e segurança de longo prazo com autenticação mútua de todas as partes. Sadio et al. [18] adotam a AEAD ChaCha20-Poly1305 para cifra fim-a-fim em MQTT e MQTT-SN, com um protótipo em Arduino UNO de pequena pegada de memória. Dahlmanns et al. [40] propõem o ENTRUST, segurança fim-a-fim baseada num servidor de

chaves que garante confidencialidade, integridade e autenticação sem qualquer alteração ao protocolo. Van Glabbeek et al. [43] propõem uma solução para comunicação muitos-para-muitos que, face ao MQTTS (MQTT sobre TLS), reduz em 80 % o *overhead* de comunicação e em 40 % o computacional no estabelecimento de uma ligação segura do lado do cliente.

5.2.6 C6 — Proteção do *broker* e do transporte

Segarra et al. [7] executam o *broker* dentro de um ambiente de execução confiável (ARM TrustZone), com um *handshake* baseado em TLS mútuo e cifra em duas camadas, usando o TEE como intermediário confiável; avaliam o protótipo com micro e macro *benchmarks* e cargas reais de uma aplicação médica. Spielvogel et al. [14] observam que um *broker* que aceita ligações seguras e inseguras reencaminha mensagens independentemente da proteção de cada salto, e propõem que o *publisher* possa exigir que a mensagem só seja entregue por ligações com o nível de segurança pretendido. Prantl et al. [13] medem o impacto do TLS no débito, no tempo de estabelecimento de ligação e na eficiência energética num microcontrolador, e concluem que esse impacto depende sobretudo das condições da rede e da frequência de restabelecimento de ligações.

5.2.7 C7 — Deteção de intrusões

Vaccari et al. [25] publicam o MQTTset, um conjunto de dados de tráfego MQTT legítimo e de ataques para treinar sistemas de deteção baseados em aprendizagem automática. Alotaibi et al. [29] usam um enquadramento distribuído (H2O) para monitorizar e classificar em tempo real comportamentos anómalos no MQTT, obtendo os melhores resultados com XGBoost.

5.2.8 C8 — Privacidade e anonimato

Buccafurri et al. [36] propõem o MQTT-A, que estende o mecanismo de *bridging* do MQTT com uma rede de *brokers* intermédios para que o *broker* final não consiga identificar a origem nem o destino, com um mecanismo de descoberta de tópicos que preserva o anonimato e sem alterações à infraestrutura MQTT normalizada.

5.3 Comparação dos mecanismos (QF3, QF4)

A Tabela 12 compara os 17 estudos que propõem mecanismos (categorias C2 a C8) segundo as propriedades de segurança garantidas, a confiança depositada no *broker*, o tipo de avaliação e a consideração de dispositivos restritos. Os três estudos de análise (C1) não propõem mecanismos e foram discutidos na secção anterior.

Cobertura das propriedades (QE3). A Figura 6 contabiliza, para os 17 mecanismos, quantos garantem cada propriedade (total ou parcialmente). A confidencialidade é a propriedade mais tratada (12 estudos), seguida da autenticação e da integridade (7 cada) e da autorização (5). Apenas 6 mecanismos funcionam, total ou parcialmente, com um *broker* não confiável. A validade temporal, a proteção contra repetição e o não repúdio não são reportados como propriedades garantidas por nenhum dos estudos, na informação extraída.

Tabela 12. Comparação dos estudos que propõem mecanismos. Propriedades: C confidencialidade, I integridade, Au autenticação, Az autorização, V validade temporal, R anti-repetição, NR não repúdio, D disponibilidade/deteção, P privacidade. BnC: funciona com *broker* não confiável. Aval.: E experimental, F formal, S simulação, A analítica. Restr.: avaliado ou desenhado para dispositivos restritos. ✓ garantido; ● parcialmente; ✗ não, por desenho; – não reportado.

ID	Estudo	Mecanismo principal	C	I	Au	Az	V	R	NR	D	P	BnC	Aval.	Restr.
C2 — Autenticação														
E08	Lohachab e Karambir [44]	Autenticação e autorização com ECC	–	–	✓	✓	–	–	–	–	–	–	E	✓
E20	Javadi et al. [37]	Autenticação mútua sem certificados (ECC)	✓	✓	✓	–	–	–	–	–	–	–	F, E, S	✓
C3 — Autorização e controlo de acesso														
E02	Niruntasukrat et al. [38]	OAuth 1.0a adaptado	–	–	●	✓	–	–	–	–	–	–	E	✓
E03	Rizzardi et al. [39]	Gestão de chaves e políticas (AUPS)	●	–	–	✓	–	–	–	–	–	–	–	–
E05	Calabretta et al. [31]	AugPAKE e *tokens* por tópico	✓	–	✓	✓	–	–	–	–	–	–	A	–
C4 — Cifra baseada em atributos														
E01	Singh et al. [28]	KP/CP-ABE sobre ECC	✓	–	–	✓	–	–	–	–	–	●	–	✓
C5 — Proteção leve fim-a-fim da mensagem														
E07	Dinculeană e Cheng [42]	Mapeamento *Value-to-HMAC*	✓	✓	–	–	–	–	–	–	–	✓	E	✓
E09	Malina et al. [45]	Três níveis de segurança	●	✓	✓	–	–	–	–	–	✓	–	–	✓
E10	Sadio et al. [18]	AEAD ChaCha20-Poly1305	✓	✓	–	–	–	–	–	–	–	✓	E	✓
E14	Dahlmanns et al. [40]	Servidor de chaves (ENTRUST)	✓	✓	✓	–	–	–	–	–	–	✓	E	–
E17	Van Glabbeek et al. [43]	Segurança muitos-para-muitos	●	●	–	–	–	–	–	–	–	●	E	✓
C6 — Proteção do broker e do transporte														
E13	Segarra et al. [7]	*Broker* em TEE (TrustZone)	✓	–	✓	–	–	–	–	–	–	●	E	–
E15	Spielvogel et al. [14]	Nível de segurança exigido por salto	●	–	–	–	–	–	–	–	–	✗	E	–
E16	Prantl et al. [13]	Avaliação do MQTT sobre TLS	✓	✓	–	–	–	–	–	–	–	✗	E	✓
C7 — Deteção de intrusões														
E12	Vaccari et al. [25]	Conjunto de dados para IDS	–	–	–	–	–	–	–	●	–	–	E	–
E19	Alotaibi et al. [29]	IDS distribuído (H2O, XGBoost)	–	–	–	–	–	–	–	●	–	–	E	–
C8 — Privacidade e anonimato														
E18	Buccafurri et al. [36]	Rede de *bridges* anónima	–	–	–	–	–	–	–	–	✓	–	E	–

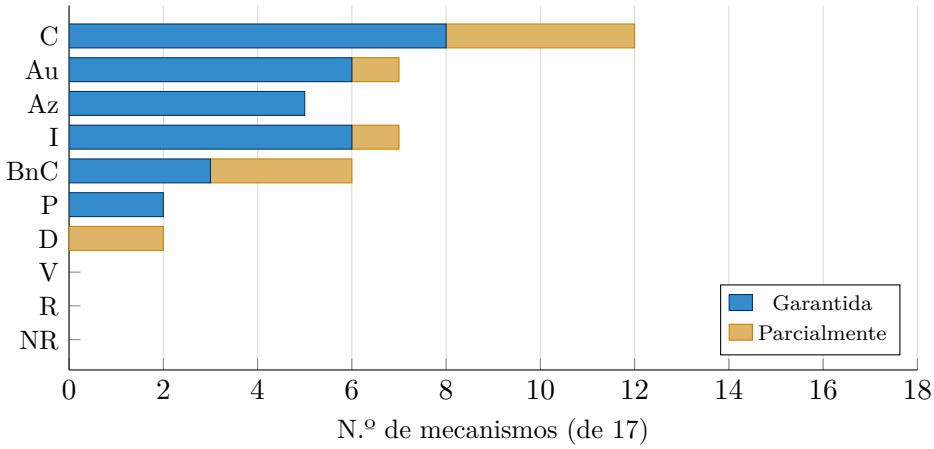


Figura 6. Número de mecanismos que garantem cada propriedade de segurança (siglas como na Tabela 12).

Avaliação (QF4). Treze dos 17 mecanismos (76,5 %) reportam avaliação experimental, mas só um combina avaliação experimental com verificação formal e simulação [37], e só um usa uma avaliação predominantemente analítica [31]. Nove mecanismos são desenhados ou avaliados explicitamente para dispositivos restritos, com plataformas que vão do Arduino UNO [18] a microcontroladores comerciais [13] e ao Raspberry Pi [37]. As métricas mais comuns são latência, memória, tempo de execução e *overhead* de comunicação; nenhum estudo mede, lado a lado, o custo de cada mecanismo e os ataques que esse mecanismo efetivamente impede.

5.4 Respostas às perguntas de investigação

QG. A literatura propõe mecanismos em três frentes: compreender as ameaças (análise de vulnerabilidades, *fuzzing*, deteção de intrusões), proteger a ligação e o *broker* (autenticação, autorização, TEE, políticas de transporte) e proteger a mensagem (cifra leve fim-a-fim, MAC, ABE, anonimato). A confidencialidade é a propriedade mais coberta, seguida da autenticação e da integridade; a independência face ao *broker* é minoritária e a validade temporal, a anti-repetição e o não repúdio não são reportadas.

QF1. As ameaças identificadas são: escuta e injeção em *brokers* mal configurados [6]; negação de serviço, incluindo ataques de baixa taxa que a cifra não evita [24]; erros de implementação detetáveis por *fuzzing* [41]; e o *broker* como ponto de exposição de todo o conteúdo [7, 40].

QF2. Os mecanismos atuam: no transporte e na ligação (TLS e a sua avaliação, políticas por salto); no *broker* (OAuth, *tokens* por tópico, políticas, TEE); na mensagem, de ponta a ponta (ABE, AEAD, HMAC, servidor de chaves); e fora do caminho de dados (deteção de intrusões). A proteção fim-a-fim é a categoria mais numerosa (C5, cinco estudos).

QF3. Ver a Tabela 12 e a Figura 6. Apenas seis mecanismos dispensam, total ou parcialmente, a confiança no *broker*; os restantes assumem-no confiável ou não o discutem.

QF4. A avaliação é maioritariamente experimental, em plataformas reais ou de baixo custo, centrada no custo do mecanismo; a verificação formal é rara.

QF5. As limitações e desafios mais referidos são o custo da segurança em dispositivos alimentados por bateria [23], a inadequação do TLS a nós restritos [18, 37], a exposição do conteúdo no *broker* [7] e a impossibilidade de um cliente impor a proteção dos restantes saltos [14].

QE1–QE3. Ver a Figura 4, a Secção 5.1 e a Figura 6.

6 Proposta: arquitetura de segurança em camadas

Esta secção propõe uma arquitetura que responde às lacunas identificadas na Secção 5. A proposta é apresentada ao nível do desenho e da sua formalização; a avaliação experimental (custo de cada camada e ataques que cada uma impede) é objeto da segunda parte do projeto, planeada na Secção 7. Uma implementação de referência em C++23, com documentação técnica completa, está disponível no repositório do projeto [11].

6.1 Princípios de desenho

D1. Defesa em profundidade (Eq. 12): proteção no transporte, na mensagem e na disponibilidade, de forma independente.

D2. O *broker* não é de confiança para o conteúdo: a confidencialidade, a integridade, a autenticidade, a validade temporal e a não repetição das mensagens não podem depender dele.

D3. Camadas independentes e comutáveis: cada mecanismo é uma camada que pode ser ativada ou desativada sem alterar as restantes, o que permite medir isoladamente o custo e o benefício de cada um.

D4. Verificações baratas primeiro, estado só depois da autenticação: rejeitar cedo o que é barato rejeitar e nunca deixar entrada não autenticada alterar estado.

D5. Estado limitado: toda a estrutura que um atacante consiga fazer crescer tem um limite superior.

6.2 Arquitetura em camadas

A comunicação de cada extremo (sensor, *gateway*) passa por uma sequência ordenada de camadas entre a aplicação e o transporte MQTT (Figura 7). Seja $\mathcal{M}$ o conjunto das mensagens e $\perp$ a rejeição. Cada camada ℓ_i define duas funções $\ell_i^{\uparrow}, \ell_i^{\downarrow} : \mathcal{M} \to \mathcal{M} \cup \{\perp\}$, com $\ell(\perp) = \perp$. Para camadas ordenadas do lado da aplicação (ℓ_1) para o lado do transporte (ℓ_n):

$$\text{Saída}(m) = \ell_n^{\downarrow} \circ \cdots \circ \ell_1^{\downarrow}(m), \tag{15}$$

$$\text{Entrada}(m) = \ell_1^{\uparrow} \circ \cdots \circ \ell_n^{\uparrow}(m). \tag{16}$$

A primeira rejeição interrompe o processamento: uma mensagem recebida que alguma camada rejeite nunca chega à aplicação. A *ordem* das camadas tem significado: com a persistência acima da segurança guarda-se texto em claro; abaixo dela, guardam-se envelopes (cifra em repouso); a limitação de tráfego fica junto ao transporte para descartar inundações antes de qualquer operação criptográfica.

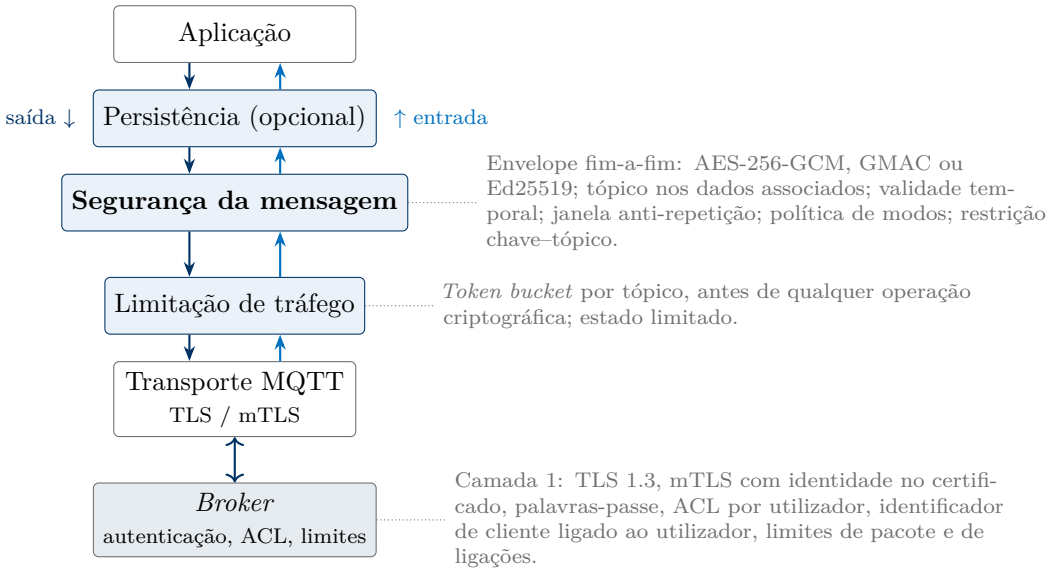


Figura 7. Arquitetura proposta: camadas entre a aplicação e o transporte, cada uma comutável de forma independente. A saída percorre as camadas de cima para baixo e a entrada de baixo para cima.

6.3 Camada de transporte e *broker*

A primeira camada usa o que os *brokers* já oferecem (Tabela 1), configurado de forma restritiva: só a porta TLS aberta (TLS 1.3); autenticação mútua por certificado, com o nome comum do certificado como identidade MQTT; palavras-passe; ACL de negação por omissão com regras parametrizadas pelo utilizador autenticado (por exemplo, `restricted/sensors/%u/#` só para escrita); identificador de cliente igual ao nome de utilizador, o que impede um cliente de tomar a sessão de outro; desativação de `$SYS`; e limites de tamanho de pacote e de número de ligações. Esta camada protege a rede e restringe quem fala com o *broker*, mas, por si só, deixa intactos os problemas P1 a P3.

6.4 Envelope fim-a-fim

A camada de segurança substitui o conteúdo de cada mensagem por um *envelope* (Figura 8), com cabeçalho fixo de 25 octetos.

Dados associados e ligação ao tópico. Sendo *cab* o cabeçalho, N o *nonce* e τ o tópico MQTT, os dados associados são

$$A = cab \,\|\, N \,\|\, \mathrm{u16}(|\tau|) \,\|\, \tau. \tag{17}$$

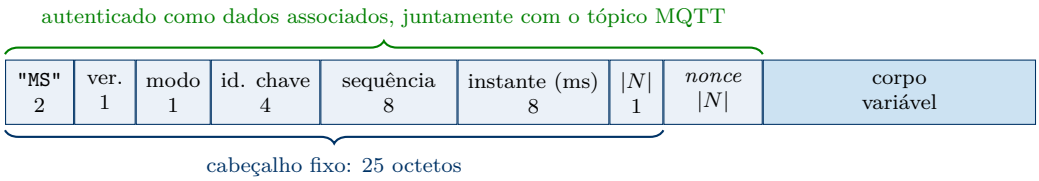


Figura 8. Formato do envelope (inteiros em *big-endian*); o número sob cada campo é o seu tamanho em octetos.

Como o tópico entra na autenticação mas não no envelope, uma mensagem válida republicada noutro tópico falha a verificação sem qualquer custo de transmissão; e como todo o cabeçalho (incluindo o modo, o identificador da chave, a sequência e o instante) é autenticado, nenhum desses campos pode ser alterado.

Modos de proteção. O remetente escolhe um de três modos, indicado no cabeçalho:

$$\textbf{cifra:} \quad \mathit{corpo} = C \,\|\, T, \qquad (C, T) = \text{AES-GCM.Enc}(K, N, P, A); \tag{18}$$

$$\textbf{autenticação:} \quad \mathit{corpo} = P \,\|\, T, \qquad T = \text{AES-GCM.Enc}(K, N, \varnothing, A \,\|\, P); \tag{19}$$

$$\textbf{assinatura:} \quad \mathit{corpo} = P \,\|\, \sigma, \qquad \sigma = \text{Ed25519.Sign}(sk, A \,\|\, P),\ N = \varnothing. \tag{20}$$

O modo de cifra garante confidencialidade e integridade; o de autenticação (GMAC) garante integridade com o conteúdo legível; o de assinatura garante integridade e *prova de origem*: o recetor guarda apenas chaves públicas e, por isso, consegue verificar, mas não forjar, mensagens dos dispositivos. O custo fixo por mensagem é

$$\omega(\text{modo}) = 25 + |N| + |T| = \begin{cases} 25 + 12 + 16 = 53 \text{ octetos} & \text{(cifra, autenticação)}, \\ 25 + 0 + 64 = 89 \text{ octetos} & \text{(assinatura)}. \end{cases} \tag{21}$$

Política do recetor contra a redução do nível de proteção. Cada recetor mantém o conjunto $\mathcal{A} \subseteq \{\text{cifra}, \text{autenticação}, \text{assinatura}\}$ dos modos que aceita e rejeita qualquer envelope cujo modo $\mu \notin \mathcal{A}$. Como μ faz parte de A, um atacante não consegue rotular uma mensagem cifrada como «apenas autenticada» sem invalidar a etiqueta, e um detentor de chave não consegue baixar o nível de proteção abaixo do que o recetor exige.

6.5 Ordem de verificação no recetor

A Tabela 13 define a sequência de verificações de um envelope recebido. A ordem decorre do princípio D4.

6.6 Validade temporal e anti-repetição

A verificação da validade temporal usa a Eq. (9) com $\Delta_a = 60$ s e $\Delta_s = 5$ s, e a anti-repetição a janela da Eq. (10) com $w = 64$, mantida por identificador de chave. Os dois mecanismos são complementares: a validade temporal sozinha deixa passar todas as repetições com menos de Δ_a; a janela sozinha não protege contra a perda do seu estado (por exemplo, reinício do recetor), situação em que a validade temporal limita a exposição a Δ_a. Para cumprir o princípio D5, o

Tabela 13. Sequência de verificações de um envelope recebido.

#	Verificação	Justificação da posição	Rejeição
1	Formato do envelope	Descarta conteúdo não protegido (por exemplo, injeções em claro)	mensagem malformada
2	Modo $\mu \in \mathcal{A}$	Barato; o modo está em A, pelo que mentir sobre ele só pode falhar	modo não aceite
3	Validade temporal, Eq. (9)	Barato; o instante está em A, pelo que alterá-lo invalida a etiqueta	mensagem expirada
4	Chave conhecida e verificação criptográfica	A partir daqui a mensagem é autêntica; a falha é sempre a mesma, sem revelar a causa (sem oráculo)	falha de autenticação
5	Restrição chave–tópico, Eq. (22)	Só depois da autenticação: entrada não autenticada não pode sondar a política	permissão negada
6	Janela anti-repetição, Eq. (10)	Só depois da autenticação (números forjados não avançam a janela) e da restrição (uma mensagem recusada não consome o seu número)	repetição detetada

número de janelas é limitado e um identificador de chave novo é recusado quando o limite é atingido. Os limites do GCM (Eq. (5)) e do espaço de sequências (2^{64}) impõem a rotação das chaves.

6.7 Restrição chave–tópico

Autenticar uma mensagem prova apenas que foi produzida com a chave k. Para que um dispositivo comprometido não publique, com a sua chave válida, nos tópicos dos outros (problema P3), cada chave tem um dono dono(k) e o recetor aplica regras de negação por omissão. Sendo F_k as regras específicas da chave, F_* os padrões gerais e σ_k a substituição $\{\texttt{\%u} \mapsto \text{dono}(k),\ \texttt{\%k} \mapsto k\}$:

$$\text{autorizada}(k, \tau) \iff \exists f \in F_k \cup \sigma_k(F_*) :\ \text{corr}(f, \tau), \tag{22}$$

com corr definida na Eq. (1). Por exemplo, com o padrão `+/sensors/%u/#`, a chave de `sensor-7` só pode publicar em `open/sensors/sensor-7/...` e `restricted/sensors/sensor-7/...`. O dono tem de ser um único nível de tópico sem carateres especiais, para que a substituição não alargue o filtro.

6.8 Gestão de chaves

Cada dispositivo d tem, por época e, uma chave AES, um par de chaves Ed25519 e o identificador $\text{id}(d, e) = e \cdot 10^6 + d$ (o *gateway* é $d = 0$). Identificadores nunca são reutilizados: um identificador reutilizado teria uma janela anti-repetição nova, na qual mensagens antigas voltariam a ser aceites. A Tabela 14 mostra que chaves cada papel detém.

A **rotação** instala as chaves da época $e + 1$ ao lado das da época e, muda os remetentes para as novas e revoga as antigas após um período de graça. A **revogação** de um dispositivo remove as suas chaves de mensagem, a sua palavra-passe no *broker* e coloca o seu certificado na CRL, atuando nas duas camadas de defesa.

Tabela 14. Distribuição de chaves por papel.

Papel	**Chaves AES**	**Chaves privadas Ed25519**	**Chaves públicas Ed25519**
Gateway	de todos os dispositivos e a sua	**apenas a sua**	de todos os dispositivos e a sua
Dispositivo d	a sua e a do *gateway* (ordens)	a sua	a do *gateway*
Atacante	—	—	— (apenas o certificado da CA)

6.9 Limitação de tráfego antes da criptografia

Junto ao transporte, uma camada aplica a Eq. (11) por tópico, rejeitando o excesso antes de qualquer verificação criptográfica. O número de baldes é limitado; quando o limite é atingido, os baldes inativos (que voltariam a estar cheios) são descartados e, se não houver nenhum, os tópicos novos partilham um único balde, pelo que um atacante não consegue criar orçamento inventando tópicos.

6.10 Mapeamento entre ameaças e mecanismos

A Tabela 15 relaciona as ameaças da Tabela 2 com os mecanismos da proposta.

Tabela 15. Ameaças e mecanismos da arquitetura proposta.

Ameaça	**Mecanismo**	**Camada**
Escuta na rede	TLS 1.3	transporte
Escuta pelo *broker* ou por subscritores de `#`	Modo de cifra; ACL	mensagem; *broker*
Adulteração do conteúdo ou do cabeçalho	Etiqueta GCM ou assinatura sobre $A \,\|\|\, P$	mensagem
Republicação noutro tópico	Tópico em A, Eq. (17)	mensagem
Repetição	Janela anti-repetição	mensagem
Mensagens antigas	Validade temporal	mensagem
Injeção de mensagens em claro	Formato do envelope e autenticação	mensagem
Redução do nível de proteção	Modo em A e política $\mathcal{A}$	mensagem
Usurpação de identidade no *broker*	Palavras-passe, mTLS, identificador ligado ao utilizador	transporte
Dispositivo comprometido a publicar por outros	Restrição chave–tópico, Eq. (22); ACL com `%u`	mensagem; *broker*
Recetor a forjar dados de dispositivos	Modo de assinatura (recetor só com chaves públicas)	mensagem
Chaves roubadas	Rotação por épocas; revogação	gestão
Inundação de um tópico	*Token bucket* antes da criptografia; limites no *broker*	disponibilidade
Esgotamento de memória	Estado limitado (janelas, baldes, repositório)	todas
Oráculo de verificação	Falha uniforme; estado só depois da autenticação	mensagem

6.11 Comparação com os trabalhos relacionados

A Tabela 16 compara a proposta com os mecanismos fim-a-fim e de autenticação mais próximos, acrescentando às propriedades da Tabela 12 três mecanismos específicos desta proposta: ligação

ao tópico (LT), política contra a redução do nível de proteção (RN) e restrição chave–tópico (CT).

Tabela 16. Posicionamento da proposta face aos trabalhos relacionados mais próximos. Siglas e símbolos como na Tabela 12; LT ligação ao tópico; RN política contra a redução do nível de proteção; CT restrição chave–tópico; Com.: camadas comutáveis em tempo de execução.

ID	Trabalho	C	I	Au	Az	V	R	NR	D	P	BnC	LT	RN	CT	Com.
E01	Singh et al. [28]	✓	–	–	✓	–	–	–	–	–	●	–	–	–	–
E05	Calabretta et al. [31]	✓	–	✓	✓	–	–	–	–	–	–	–	–	–	–
E07	Dinculeană e Cheng [42]	✓	✓	–	–	–	–	–	–	–	✓	–	–	–	–
E09	Malina et al. [45]	●	✓	✓	–	–	–	–	–	✓	–	–	–	–	–
E10	Sadio et al. [18]	✓	✓	–	–	–	–	–	–	–	✓	–	–	–	–
E13	Segarra et al. [7]	✓	–	✓	–	–	–	–	–	–	●	–	–	–	–
E14	Dahlmanns et al. [40]	✓	✓	✓	–	–	–	–	–	–	✓	–	–	–	–
E20	Javadi et al. [37]	✓	✓	✓	–	–	–	–	–	–	–	–	–	–	–
—	**Proposta**	✓	✓	✓	✓	✓	✓	✓	●	✗	✓	✓	✓	✓	✓

A proposta não supera os trabalhos relacionados em todas as dimensões: não oferece anonimato [36], não protege o próprio *broker* com um TEE [7], não oferece confidencialidade de grupo por atributos [28] e não tem verificação formal [37]. O seu contributo está na *combinação*, numa só camada fim-a-fim, de propriedades que a literatura analisada trata separadamente ou não reporta (ligação ao tópico, validade temporal com anti-repetição, política contra a redução do nível de proteção, restrição chave–tópico e não repúdio opcional) e na organização em camadas comutáveis, que permite medir o custo e o benefício de cada mecanismo isoladamente.

6.12 Limitações conhecidas

- **Chaves pré-partilhadas**: a distribuição inicial das chaves assume um canal seguro; um acordo de chaves por dispositivo (por exemplo, ECDH) eliminaria os segredos pré-partilhados.
- **Chave de grupo nas ordens**: nos modos AES todos os atuadores detêm a chave do *gateway*, pelo que um atuador comprometido pode forjar ordens para os outros; o modo de assinatura resolve-o, a um custo computacional superior.
- **Limitação por tópico**: o tópico é escolhido por quem publica, pelo que um atacante que inunde o tópico de uma vítima consome também o orçamento da vítima; limites por cliente pertencem ao *broker*.
- **Estado da janela não persistente**: o reinício do recetor apaga as janelas anti-repetição, ficando a proteção limitada à validade temporal (Δ_a).
- **Dados falsos mas autênticos**: um dispositivo comprometido continua a poder publicar dados falsos nos seus próprios tópicos; só a deteção e a revogação o travam.

7 Objetivo e plano da segunda parte do projeto

A primeira parte identificou as lacunas do estado da arte e propôs uma arquitetura para as tratar. A segunda parte tem um objetivo concreto: **implementar a arquitetura e medir,**

num dispositivo restrito (Raspberry Pi), quanto custa cada camada em desempenho e quanto protege, isoladamente e em combinação, para identificar a configuração — ou o pequeno conjunto de configurações — que oferece a maior proteção com o menor impacto no desempenho. Este objetivo responde diretamente à lacuna L5 (Secção 8): na literatura analisada, o custo de um mecanismo e os ataques que ele impede não são medidos no mesmo ensaio.

A implementação de referência [11] já permite ativar e desativar cada camada de forma independente, e inclui as duas ferramentas de medição usadas no plano: um conjunto de *microbenchmarks* do encadeamento de camadas e um laboratório de carga com *broker*, *gateway*, sensores simulados e um atacante.

7.1 Perguntas experimentais

QP1. Qual é o custo de cada camada num Raspberry Pi, em tempo de processador, latência, débito, memória e octetos acrescentados, e quanto difere do custo num computador de secretária?

QP2. Que ataques impede cada camada, e que ataques só são impedidos pela combinação de camadas?

QP3. Como varia o custo com o tamanho da mensagem, a taxa de envio e o número de dispositivos, e a partir de que carga o Raspberry Pi satura?

QP4. Qual é o peso da aceleração criptográfica por *hardware* no custo de cada configuração, e a configuração recomendada muda quando ela não existe?

QP5. Que configurações são ótimas de Pareto (nenhuma outra protege mais por menor custo) e qual delas recomendar?

7.2 Configurações em estudo

As configurações da Tabela 17 acrescentam uma camada ou um mecanismo de cada vez, o que permite atribuir a cada passo o seu custo e o seu benefício marginais. A configuração K10 isola o contributo do TLS quando o envelope fim-a-fim já está ativo.

Todas as configurações correspondem a combinações de parâmetros do laboratório de carga (`broker.mode`, `payload.protection`, `payload.freshness`, `payload.replay`, `payload.key_binding`, `payload.rate_limit`), e K9 coincide com a predefinição `hardened`. A matriz completa é, por isso, executada de forma automática e reprodutível.

7.3 Plataforma experimental

As medições são feitas a dois níveis, ambos repetidos num computador de secretária como referência, para quantificar o fator de abrandamento do dispositivo restrito.

Tabela 17. Configurações a avaliar. Transporte: TLS 1.3 com autenticação mútua por certificado, palavras-passe, ACL e identificador de cliente ligado ao utilizador. VT validade temporal; R anti-repetição; CT restrição chave–tópico; LT limitação de tráfego antes da criptografia.

ID	Transporte	Envelope	VT	R	CT	LT	O que acrescenta
K0	—	—	—	—	—	—	referência, sem proteção
K1	✓	—	—	—	—	—	proteção de cada salto; quem fala com o *broker*
K2	✓	GMAC	—	—	—	—	integridade fim-a-fim e ligação ao tópico
K3	✓	AES-GCM	—	—	—	—	+ confidencialidade face ao *broker*
K4	✓	AES-GCM	✓	—	—	—	+ rejeição de mensagens antigas
K5	✓	AES-GCM	—	✓	—	—	+ rejeição de repetições
K6	✓	AES-GCM	✓	✓	—	—	envelope completo
K7	✓	AES-GCM	✓	✓	✓	—	+ contenção de um dispositivo comprometido
K8	✓	AES-GCM	✓	✓	✓	✓	+ proteção contra inundação
K9	✓	Ed25519	✓	✓	✓	✓	+ não repúdio (prova de origem)
K10	—	AES-GCM	✓	✓	✓	—	envelope completo sem TLS

Nível 1: custo das camadas no dispositivo. Os *microbenchmarks* são compilados e executados nativamente num Raspberry Pi 5 (Broadcom BCM2712, quatro núcleos Arm Cortex-A76 a 2,4 GHz, 8 GB de memória LPDDR4X e armazenamento SSD de 256 GB). Cada iteração percorre o caminho completo *publisher* → *broker* em memória → recetor, sem rede, isolando o custo de processador de cada camada para mensagens de 16 B, 256 B, 4 KiB e 64 KiB. É o custo que um sensor ou um *gateway* restrito paga por mensagem.

Aceleração criptográfica por *hardware*. Os núcleos Cortex-A76 dispõem das extensões criptográficas da arquitetura Armv8 (instruções AES e multiplicação polinomial, usada pelo GCM), que aceleram o AES-GCM, mas não o Ed25519. Muitos dispositivos IoT não têm estas instruções. Para medir o seu impacto, as configurações selecionadas são executadas duas vezes no mesmo Raspberry Pi: com a aceleração ativa e com ela desativada, o que no OpenSSL, usado tanto pela implementação como pelo Mosquitto, se faz com a variável de ambiente `OPENSSL_armcap=0`. A comparação abrange o envelope e o TLS; no TLS mede-se também a suite TLS_CHACHA20_POLY1305_SHA256, a alternativa desenhada para processadores sem AES em *hardware* [17].

Nível 2: sistema completo sob carga. O *broker* Mosquitto e o *gateway* correm no Raspberry Pi, que faz de *gateway* de periferia; os sensores simulados e o atacante correm noutras máquinas da mesma rede local (Ethernet), como agentes distribuídos do laboratório de carga. Este nível acrescenta o que o primeiro não vê: o TLS, o *broker*, a rede, a concorrência de muitos dispositivos e os ataques reais.

Para reduzir a variabilidade, fixa-se o regulador de frequência do processador em `performance`, monitoriza-se a temperatura e o estrangulamento térmico do Raspberry Pi durante cada ensaio (descartando ensaios com estrangulamento) e usa-se a mesma versão do Mosquitto em todas as máquinas.

7.4 Métricas

Tabela 18. Métricas de custo e de benefício.

Métrica	Definição	Nível
Custo		
Processador por mensagem	µs de CPU por mensagem (envio e receção)	1, 2
Latência	p50 e p99, do envio pelo sensor à entrega à aplicação	2
Débito máximo sustentado	maior taxa com perda $< 1\,\%$ e p99 dentro do limite	2
Octetos acrescentados	octetos na rede menos o conteúdo; teoricamente 53 ou 89 (Eq. 21)	1
Memória	pico de memória residente do *gateway* e do *broker*	2
Estabelecimento de ligação	tempo de ligação (TLS e CONNECT) e custo das religações	2
Energia (opcional)	consumo do Raspberry Pi, com medidor USB	2
Benefício		
Ataques impedidos	para cada ataque $a \in \mathcal{A}$, $b_a(c) = 1$ se a configuração c o impede	1, 2
Fuga de informação	fração das mensagens legítimas legível por um subscritor de `#`	1, 2

O conjunto de ataques $\mathcal{A}$ cobre as ameaças da Tabela 2 e é executado pelo atacante do laboratório: escuta na rede; escuta por um subscritor de `#`; injeção de mensagens em claro; adulteração; repetição; republicação noutro tópico; usurpação de identidade no *broker*; publicação nos tópicos de outro dispositivo com uma chave válida (dispositivo comprometido); redução do nível de proteção; e inundação de um tópico.

7.5 Critério de escolha da melhor configuração

Proteção. A proteção de uma configuração c é a fração ponderada dos ataques que impede,

$$S(c) = \frac{\sum_{a \in \mathcal{A}} w_a \, b_a(c)}{\sum_{a \in \mathcal{A}} w_a}, \qquad 0 \le S(c) \le 1, \tag{23}$$

com pesos $w_a = 1$ por omissão; uma análise de sensibilidade repete a escolha com pesos proporcionais à gravidade de cada ameaça.

Custo. Cada métrica de custo m é normalizada pela configuração de referência e agregada com pesos v_m que somam 1:

$$C(c) = \sum_{m} v_m \, \frac{m(c)}{m(\mathrm{K0})}, \tag{24}$$

dando por omissão maior peso ao processador por mensagem e à latência p99 no Raspberry Pi, que são os recursos escassos num dispositivo restrito. Nos octetos usa-se o total na rede (e não só o acrescentado), para que a referência não seja nula, e no débito, que é melhor quanto maior, usa-se o inverso da razão.

Exequibilidade. Uma configuração só é candidata se, no Raspberry Pi, sustentar a taxa de mensagens pretendida R_{alvo} com latência $p99 \le L_{\max}$. Estes limites dependem do cenário de aplicação (número de dispositivos, frequência das mensagens e tolerância do serviço a atrasos), que só será definido na segunda parte. Os valores de R_{alvo} e $L_{\max}$ ficam, por isso, em aberto:

serão fixados e justificados no segundo relatório, antes de executada a matriz completa, para que a escolha dos limites não seja influenciada pelos resultados.

Escolha. A configuração c domina c' se $S(c) \geq S(c')$ e $C(c) \leq C(c')$, com pelo menos uma desigualdade estrita. As configurações exequíveis não dominadas formam a *fronteira de Pareto* $\mathcal{P}$, e a configuração recomendada é a mais barata entre as que atingem a proteção máxima:

$$c^* = \underset{c \in \mathcal{P},\ S(c)=S_{\max}}{\arg\min} C(c). \tag{25}$$

Para os casos em que uma proteção ligeiramente inferior seja aceitável, reporta-se também o custo marginal de cada passo ao longo da fronteira, $\Delta C/\Delta S$, que mostra que mecanismos compram mais proteção por unidade de custo.

7.6 Procedimento

Cada célula da matriz começa com um período de estabilização de 3 s, seguido de uma janela de medição de 30 s, e é repetida 10 vezes; reporta-se a mediana com um intervalo de confiança de 95 % obtido por *bootstrap*. Para manter a matriz exequível, os fatores variam um de cada vez a partir de um cenário de referência:

- todas as configurações K0–K10 com o cenário de referência (256 B);
- tamanho da mensagem (16 B a 64 KiB) para K0, K3, K6, K8 e K9;
- taxa e número de sensores, aumentados até à saturação, para as mesmas configurações, o que dá o débito máximo sustentado de cada uma;
- K0, K1, K3, K6, K8 e K9 com e sem aceleração criptográfica por *hardware*, e K1 com a suite ChaCha20-Poly1305 no TLS;
- os ataques de $\mathcal{A}$ contra cada configuração, com o tráfego legítimo ativo, verificando também que nenhuma mensagem legítima é rejeitada.

7.7 Hipóteses

H1. O envelope com AES-256-GCM (K3–K6) tem um custo por mensagem pequeno face à latência da rede, também no Raspberry Pi. Na máquina de desenvolvimento, K6 custa cerca de 5,4 µs por mensagem de 256 B, de ponta a ponta.

H2. A validade temporal, a anti-repetição e a restrição chave–tópico têm custo marginal quase nulo (comparações, um mapa de bits e a correspondência de um filtro): uma vez paga a cifra, aumentam S quase sem aumentar C.

H3. As assinaturas Ed25519 (K9) custam cerca de 40 vezes mais processador do que o AES-GCM (cerca de 205 µs contra 5,4 µs por mensagem na máquina de desenvolvimento), pelo que só se justificam onde o não repúdio é necessário, por exemplo nas ordens enviadas aos atuadores.

H4. O custo do TLS concentra-se no estabelecimento da ligação, como observado em [13], e depende sobretudo da frequência de religação.

H5. Sob inundação, a limitação de tráfego antes da criptografia (K8) reduz o processador gasto pelo *gateway* face a K7.

H6. Sem aceleração por *hardware*, o custo do AES-GCM aumenta significativamente, tanto no envelope como no TLS, reduzindo a diferença para o Ed25519; o ChaCha20-Poly1305 torna-se, nesse caso, a cifra mais barata no TLS.

Se H1 e H2 se confirmarem, a configuração recomendada, com aceleração por *hardware*, será K8: proteção completa, exceto o não repúdio, a um custo próximo do da cifra isolada; K9 seria reservada aos fluxos que exigem prova de origem. Os resultados podem refutar esta expectativa, e é precisamente isso que a segunda parte pretende verificar.

7.8 Resultados a entregar

- Uma tabela de custo e benefício por configuração, no Raspberry Pi e no computador de referência, com o fator de abrandamento entre ambos.
- O custo de cada configuração com e sem aceleração criptográfica por *hardware*, e a configuração recomendada em cada caso.
- O gráfico de $S(c)$ contra $C(c)$, com a fronteira de Pareto assinalada.
- A configuração recomendada c^* (Eq. 25), com justificação, e recomendações por perfil de utilização (por exemplo, sensores de telemetria contra atuadores críticos).
- Os *scripts*, as configurações e os dados brutos no repositório do projeto, para que todas as medições possam ser repetidas.

8 Discussão

8.1 Lacunas do estado da arte

A comparação das Secções 5 e 6 evidencia cinco lacunas.

L1. A autenticidade raramente é acompanhada de validade temporal nem de anti-repetição. Nenhum dos mecanismos analisados reporta a verificação de carimbos temporais ou a proteção contra repetição como propriedade garantida. No MQTT, onde os duplicados legítimos do QoS 1 coexistem com repetições maliciosas, a ausência destes mecanismos permite reinjetar mensagens autênticas indefinidamente.

L2. A mensagem não é ligada ao seu contexto. A ligação criptográfica ao tópico, a proteção do modo contra a redução do nível de proteção e a restrição dos tópicos em que cada chave pode publicar não aparecem nos estudos analisados como mecanismos explícitos, apesar de corresponderem a ameaças concretas (mudança de tópico, *downgrade*, dispositivo comprometido).

L3. O *broker* continua, em regra, a ser de confiança. Só seis dos 17 mecanismos dispensam, total ou parcialmente, a confiança no *broker*; a maioria das soluções de autenticação e autorização reforça o *broker* em vez de o tornar irrelevante para a segurança do conteúdo.

L4. O não repúdio está ausente. As soluções baseiam-se em segredos partilhados (palavras-passe, chaves simétricas, ABE), o que não impede quem detém o segredo — incluindo o recetor — de forjar mensagens em nome do remetente.

L5. Custo e benefício não são medidos em conjunto. As avaliações medem o custo do mecanismo, mas raramente o relacionam, no mesmo ensaio, com os ataques que o mecanismo impede; e os mecanismos não são comparáveis entre si por usarem plataformas, cargas e métricas diferentes.

A arquitetura proposta responde diretamente a L1, L2, L3 e L4, e o seu desenho em camadas comutáveis foi pensado para que a segunda parte do projeto responda a L5 (Secção 7).

8.2 Ameaças à validade

Seguindo [9], identificam-se as principais ameaças à validade desta revisão e as medidas de mitigação adotadas (Tabela 19).

Tabela 19. Ameaças à validade da revisão e mitigação.

Tipo	Ameaça	Mitigação
Construção	A *string* pode não captar estudos que usem outra terminologia	Grupos de sinónimos; refinamento após a leitura das revisões; inclusão de MQTT-SN e de termos de deteção
Seleção	Enviesamento na aplicação dos critérios	Dois revisores independentes; kappa de Cohen (Eq. 13); resolução das divergências por discussão
Extração	Subjetividade na classificação das propriedades; um estudo pode garantir uma propriedade sem a descrever	Formulário fixo; símbolo «não reportado» distinto de «ausente por desenho»; confirmação na leitura integral
Externa	Bases de dados e língua limitam a cobertura; enviesamento de publicação	Cinco bases de dados; inglês e português; estudos de revista, conferência e *workshop*
Conclusão	Os números por propriedade dependem da granularidade das categorias	Taxonomia e critérios publicados; dados de extração no Anexo B

A ameaça mais relevante é a da extração: as conclusões L1, L2 e L4 assentam em propriedades *não reportadas*, o que não equivale a propriedades *ausentes*. Por isso, a Tabela 12 distingue explicitamente os dois casos e a discussão fala em propriedades «não reportadas».

9 Conclusões e trabalho futuro

9.1 Conclusões

Este trabalho apresentou uma revisão sistemática da literatura sobre mecanismos de segurança para comunicações IoT baseadas em MQTT, conduzida segundo um protocolo explícito — perguntas de investigação, PICOC, *strings* de pesquisa por base de dados, critérios de inclusão,

exclusão e qualidade, leitura em três passagens e formulário de extração — e relatada com o diagrama PRISMA. Foram analisados 20 estudos primários (2015–2026) e 5 revisões relacionadas.

As principais conclusões são as seguintes:

- O MQTT delega a segurança na implementação, e o TLS, por terminar no *broker*, não protege as mensagens de um *broker* comprometido nem de clientes com acesso legítimo, como mostram os estudos de análise de ameaças.
- A literatura organiza-se em oito categorias. A proteção leve fim-a-fim da mensagem é a mais numerosa, e a confidencialidade, a autenticação e a integridade são as propriedades mais tratadas.
- A validade temporal e a anti-repetição, a ligação da mensagem ao tópico, a política contra a redução do nível de proteção, a restrição chave–tópico e o não repúdio são pouco ou nada reportados, e a maioria das soluções continua a confiar no *broker*.
- As avaliações medem o custo dos mecanismos, mas raramente o relacionam com os ataques efetivamente impedidos.

Com base nestas lacunas, propôs-se uma arquitetura de segurança em camadas independentes e comutáveis, que combina defesa no transporte, um envelope fim-a-fim formalmente especificado (AES-256-GCM, GMAC ou Ed25519, com o tópico e o cabeçalho nos dados associados, validade temporal, janela anti-repetição, política de modos e restrição chave–tópico) e limitação de tráfego antes de qualquer operação criptográfica. A proposta não pretende substituir trabalhos com objetivos distintos, como o anonimato ou a proteção do *broker* por TEE, mas combinar numa só camada propriedades que a literatura trata em separado.

9.2 Trabalho futuro

- **Avaliação experimental (segunda parte do projeto)**: executar o plano da Secção 7 num Raspberry Pi, medir o custo e os ataques impedidos por cada configuração e escolher, pela fronteira de Pareto, a que dá a maior proteção com o menor impacto no desempenho, respondendo à lacuna L5.
- **Verificação formal** das propriedades do envelope, à semelhança de [37].
- **Acordo de chaves por dispositivo** (por exemplo, ECDH autenticado), eliminando chaves pré-partilhadas, e persistência do estado anti-repetição.
- **Cifras para nós sem AES em *hardware***, como o ChaCha20-Poly1305 [17, 18], e cifras resistentes à reutilização de *nonces* para chaves de longa duração.
- **Integração com deteção de intrusões** [25, 29], usando as rejeições de cada camada como sinal.
- **Atualização periódica da revisão**, reaplicando o protocolo da Secção 3.

Referências

[1] J. Dizdarević, F. Carpio, A. Jukan, and X. Masip-Bruin, "A survey of communication protocols for Internet of Things and related challenges of fog and cloud computing integration," *ACM Computing Surveys*, vol. 51, no. 6, pp. 1–29, 2019.

[2] A. Banks and R. Gupta, "MQTT version 3.1.1," OASIS, OASIS Standard, Oct. 2014. [Online]. Available: https://docs.oasis-open.org/mqtt/mqtt/v3.1.1/os/mqtt-v3.1.1-os.html

[3] A. Banks, E. Briggs, K. Borgendale, and R. Gupta, "MQTT version 5.0," OASIS, OASIS Standard, Mar. 2019. [Online]. Available: https://docs.oasis-open.org/mqtt/mqtt/v5.0/os/mqtt-v5.0-os.html

[4] R. A. Light, "Mosquitto: Server and client implementation of the MQTT protocol," *The Journal of Open Source Software*, vol. 2, no. 13, p. 265, 2017.

[5] E. Rescorla, "The transport layer security (TLS) protocol version 1.3," RFC 8446, IETF, Aug. 2018.

[6] S. Andy, B. Rahardjo, and B. Hanindhito, "Attack scenarios and security analysis of MQTT communication protocol in IoT system," in *Proc. 4th Int. Conf. Electrical Engineering, Computer Science and Informatics (EECSI)*, 2017, pp. 1–6.

[7] C. Segarra, R. Delgado-Gonzalo, and V. Schiavoni, "MQT-TZ: Hardening IoT brokers using ARM TrustZone (practical experience report)," in *Proc. Int. Symp. Reliable Distributed Systems (SRDS)*, 2020, pp. 256–265.

[8] C. Kolias, G. Kambourakis, A. Stavrou, and J. Voas, "DDoS in the IoT: Mirai and other botnets," *Computer*, vol. 50, no. 7, pp. 80–84, 2017.

[9] B. Kitchenham and S. Charters, "Guidelines for performing systematic literature reviews in software engineering," Keele University and Durham University, Technical Report EBSE-2007-01, version 2.3, 2007.

[10] M. J. Page, J. E. McKenzie, P. M. Bossuyt, I. Boutron, T. C. Hoffmann, C. D. Mulrow, L. Shamseer, J. M. Tetzlaff, E. A. Akl, S. E. Brennan *et al.*, "The PRISMA 2020 statement: An updated guideline for reporting systematic reviews," *BMJ*, vol. 372, p. n71, 2021.

[11] Autores do projeto, "mqtt-secure: Arquitetura de segurança em camadas para comunicações IoT baseadas em MQTT," Repositório GitHub, 2026. [Online]. Available: https://github.com/joaoaeafonso/mqtt_secure

[12] T. Dierks and E. Rescorla, "The transport layer security (TLS) protocol version 1.2," RFC 5246, IETF, Aug. 2008.

[13] T. Prantl, L. Iffländer, S. Herrnleben, S. Engel, S. Kounev, and C. Krupitzer, "Performance impact analysis of securing MQTT using TLS," in *Proc. ACM/SPEC Int. Conf. Performance Engineering (ICPE)*, 2021, pp. 241–248.

[14] K. Spielvogel, H. C. Pöhls, and J. Posegga, "TLS beyond the broker: Enforcing fine-grained security and trust in publish/subscribe environments for IoT," in *Security and Trust Management (STM 2021)*, ser. Lecture Notes in Computer Science. Springer, 2021, pp. 145–162.

[15] M. J. Dworkin, "Recommendation for block cipher modes of operation: Galois/Counter Mode (GCM) and GMAC," National Institute of Standards and Technology, NIST Special Publication 800-38D, 2007.

[16] H. Böck, A. Zauner, S. Devlin, J. Somorovsky, and P. Jovanovic, "Nonce-disrespecting adversaries: Practical forgery attacks on GCM in TLS," in *Proc. 10th USENIX Workshop on Offensive Technologies (WOOT 16)*. Austin, TX, USA: USENIX Association, 2016. [Online]. Available: https://www.usenix.org/conference/woot16/workshop-program/presentation/bock

[17] Y. Nir and A. Langley, "ChaCha20 and Poly1305 for IETF protocols," RFC 8439, IETF, Jun. 2018.

[18] O. Sadio, I. Ngom, and C. Lishou, "Lightweight security scheme for MQTT/MQTT-SN protocol," in *Proc. 6th Int. Conf. Internet of Things: Systems, Management and Security (IOTSMS)*, 2019, pp. 119–123.

[19] H. Krawczyk, M. Bellare, and R. Canetti, "HMAC: Keyed-hashing for message authentication," RFC 2104, IETF, Feb. 1997.

[20] D. J. Bernstein, N. Duif, T. Lange, P. Schwabe, and B.-Y. Yang, "High-speed high-security signatures," *Journal of Cryptographic Engineering*, vol. 2, no. 2, pp. 77–89, 2012.

[21] S. Josefsson and I. Liusvaara, "Edwards-curve digital signature algorithm (EdDSA)," RFC 8032, IETF, Jan. 2017.

[22] S. Kent, "IP encapsulating security payload (ESP)," RFC 4303, IETF, Dec. 2005.

[23] A. J. Hintaw, S. Manickam, M. F. Aboalmaaly, and S. Karuppayah, "MQTT vulnerabilities, attack vectors and solutions in the Internet of Things (IoT)," *IETE Journal of Research*, vol. 69, no. 6, pp. 3368–3397, 2023.

[24] I. Vaccari, M. Aiello, and E. Cambiaso, "SlowITe, a novel denial of service attack affecting MQTT," *Sensors*, vol. 20, no. 10, p. 2932, 2020.

[25] I. Vaccari, G. Chiola, M. Aiello, M. Mongelli, and E. Cambiaso, "MQTTset, a new dataset for machine learning techniques on MQTT," *Sensors*, vol. 20, no. 22, p. 6578, 2020.

[26] G. Perrone, M. Vecchio, R. Pecori, and R. Giaffreda, "The day after Mirai: A survey on MQTT security solutions after the largest cyber-attack carried out through an army of IoT devices," in *Proc. 2nd Int. Conf. Internet of Things, Big Data and Security (IoTBDS)*, 2017, pp. 246–253.

[27] S. Lakshminarayana, A. Praseed, and P. S. Thilagam, "Securing the IoT application layer from an MQTT protocol perspective: Challenges and research prospects," *IEEE Communications Surveys & Tutorials*, vol. 26, no. 4, pp. 2510–2546, 2024.

[28] M. Singh, M. A. Rajan, V. L. Shivraj, and P. Balamuralidhar, "Secure MQTT for Internet of Things (IoT)," in *Proc. 5th Int. Conf. Communication Systems and Network Technologies (CSNT)*, 2015, pp. 746–751.

[29] N. S. Alotaibi, H. I. S. Ahmed, S. O. M. Kamel, and G. F. ElKabbany, "Secure enhancement for MQTT protocol using distributed machine learning framework," *Sensors*, vol. 24, no. 5, p. 1638, 2024.

[30] M. Calabretta, R. Pecori, and L. Veltri, "A token-based protocol for securing MQTT communications," in *Proc. 26th Int. Conf. Software, Telecommunications and Computer Networks (SoftCOM)*, 2018, pp. 1–6.

[31] M. Calabretta, R. Pecori, M. Vecchio, and L. Veltri, "MQTT-Auth: A token-based solution to endow MQTT with authentication and authorization capabilities," *Journal of Communications Software and Systems*, vol. 14, no. 4, 2018.

[32] J. Cohen, "A coefficient of agreement for nominal scales," *Educational and Psychological Measurement*, vol. 20, no. 1, pp. 37–46, 1960.

[33] S. Keshav, "How to read a paper," *ACM SIGCOMM Computer Communication Review*, vol. 37, no. 3, pp. 83–84, 2007.

[34] G. Nebbione and M. C. Calzarossa, "Security of IoT application layer protocols: Challenges and findings," *Future Internet*, vol. 12, no. 3, p. 55, 2020.

[35] S. U. A. Laghari, W. Li, S. Manickam, P. Nanda, A. K. Al-Ani, and S. Karuppayah, "Securing MQTT ecosystem: Exploring vulnerabilities, mitigations, and future trajectories," *IEEE Access*, vol. 12, pp. 139 273–139 289, 2024.

[36] F. Buccafurri, V. De Angelis, and S. Lazzaro, "MQTT-A: A broker-bridging P2P architecture to achieve anonymity in MQTT," *IEEE Internet of Things Journal*, vol. 10, no. 17, pp. 15 443–15 463, 2023.

[37] A. Javadi, S. Rostampour, Y. Bendavid, P. Pahlevani, S. Sadeghi, N. Bagheri, H. K. Nazari, M. Reisslein, and F. H. P. Fitzek, "CMAP: Certificateless MQTT-based authentication protocol for medical IoT," *IEEE Access*, vol. 14, pp. 60 836–60 852, 2026.

[38] A. Niruntasukrat, C. Issariyapat, P. Pongpaibool, K. Meesublak, P. Aiumsupucgul, and A. Panya, "Authorization mechanism for MQTT-based Internet of Things," in *Proc. IEEE Int. Conf. Communications Workshops (ICC)*, 2016, pp. 290–295.

[39] A. Rizzardi, S. Sicari, D. Miorandi, and A. Coen-Porisini, "AUPS: An open source AUthenticated Publish/Subscribe system for the Internet of Things," *Information Systems*, vol. 62, pp. 29–41, 2016.

[40] M. Dahlmanns, J. Pennekamp, I. B. Fink, B. Schoolmann, K. Wehrle, and M. Henze, "Transparent end-to-end security for publish/subscribe communication in cyber-physical systems," in *Proc. ACM Workshop on Secure and Trustworthy Cyber-Physical Systems (SaT-CPS)*, 2021, pp. 78–87.

[41] S. H. Ramos, M. T. Villalba, and R. Lacuesta, "MQTT security: A novel fuzzing approach," *Wireless Communications and Mobile Computing*, vol. 2018, p. 8261746, 2018.

[42] D. Dinculeană and X. Cheng, "Vulnerabilities and limitations of MQTT protocol used between IoT devices," *Applied Sciences*, vol. 9, no. 5, p. 848, 2019.

[43] R. Van Glabbeek, D. Deac, T. Perale, K. Steenhaut, and A. Braeken, "Flexible and efficient security framework for many-to-many communication in a publish/subscribe architecture," *Sensors*, vol. 22, no. 19, p. 7391, 2022.

[44] A. Lohachab and Karambir, "ECC based inter-device authentication and authorization scheme using MQTT for IoT networks," *Journal of Information Security and Applications*, vol. 46, pp. 1–12, 2019.

[45] L. Malina, G. Srivastava, P. Dzurenda, J. Hajny, and R. Fujdiak, "A secure publish/subscribe protocol for Internet of Things," in *Proc. 14th Int. Conf. Availability, Reliability and Security (ARES)*. ACM, 2019, pp. 1–10.

A *Strings* de pesquisa por base de dados

Todas as pesquisas foram restringidas a publicações de 2014 a 2026. Os grupos G1 a G3 são os da Tabela 5; nas *strings* secundárias acrescenta-se, com `AND`, o grupo G4.

IEEE Xplore (*Command Search*, campo *All Metadata*)

```
("All Metadata":"MQTT"OR "All Metadata":"MQTT-SN"OR "All Metadata":"MQ Telemetry Transport"OR
"All Metadata":"Message Queuing Telemetry Transport"OR "All Metadata":"Message Queue Telemetry
Transport") AND ("All Metadata":security OR "All Metadata":secure OR "All
Metadata":authentication OR "All Metadata":authorization OR "All Metadata":"access control"OR
"All Metadata":encryption OR "All Metadata":confidentiality OR "All Metadata":integrity OR "All
Metadata":privacy OR "All Metadata":attack* OR "All Metadata":vulnerabilit* OR "All
Metadata":intrusion) AND ("All Metadata":"Internet of Things"OR "All Metadata":IoT OR "All
Metadata":IIoT OR "All Metadata":"publish/subscribe"OR "All Metadata":"publish-subscribe"OR "All
Metadata":"machine-to-machine"OR "All Metadata":M2M)
Filtro: Year 2014-2026; Conferences, Journals.
```

Scopus

```
TITLE-ABS-KEY ( ( "MQTT"OR "MQTT-SN"OR "MQ Telemetry Transport"OR "Message Queuing Telemetry
Transport"OR "Message Queue Telemetry Transport") AND ( "security"OR "secure"OR
"authentication"OR "authorization"OR "access control"OR "encryption"OR "confidentiality"OR
"integrity"OR "privacy"OR attack* OR vulnerabilit* OR "intrusion") AND ( "Internet of Things"OR
"IoT"OR "IIoT"OR "publish/subscribe"OR "publish-subscribe"OR "machine-to-machine"OR "M2M") ) AND
PUBYEAR > 2013 AND PUBYEAR < 2027 AND ( LIMIT-TO ( DOCTYPE , "ar") OR LIMIT-TO ( DOCTYPE , "cp")
) AND ( LIMIT-TO ( LANGUAGE , "English") OR LIMIT-TO ( LANGUAGE , "Portuguese") )
```

ACM Digital Library (pesquisa avançada, campos *Title*, *Abstract*, *Keywords*)

```
[[Title: "mqtt"] OR [Abstract: "mqtt"] OR [Keywords: "mqtt"] OR [Abstract: "message queuing
telemetry transport"] OR [Abstract: "mq telemetry transport"]] AND [[Abstract: security] OR
[Abstract: secure] OR [Abstract: authentication] OR [Abstract: authorization] OR [Abstract:
"access control"] OR [Abstract: encryption] OR [Abstract: confidentiality] OR [Abstract:
integrity] OR [Abstract: privacy] OR [Abstract: attack*] OR [Abstract: vulnerabilit*] OR
[Abstract: intrusion]] AND [[Abstract: "internet of things"] OR [Abstract: iot] OR [Abstract:
iiot] OR [Abstract: "publish/subscribe"] OR [Abstract: "publish-subscribe"] OR [Abstract:
"machine-to-machine"] OR [Abstract: m2m]]
Filtro: Publication Date 2014-2026.
```

Web of Science (Core Collection, campo *Topic*)

```
TS=( ("MQTT"OR "MQTT-SN"OR "MQ Telemetry Transport"OR "Message Queuing Telemetry Transport"OR
"Message Queue Telemetry Transport") AND (security OR secure OR authentication OR authorization
OR "access control"OR encryption OR confidentiality OR integrity OR privacy OR attack* OR
vulnerabilit* OR intrusion) AND ("Internet of Things"OR IoT OR IIoT OR "publish/subscribe"OR
"publish-subscribe"OR "machine-to-machine"OR M2M) )
Filtro: PY=(2014-2026); Document Types: Article, Proceedings Paper.
```

ScienceDirect (campo *Title, abstract or author-specified keywords*)

O ScienceDirect não suporta o carácter universal `*` e limita o número de operadores booleanos por campo; a *string* foi, por isso, dividida em duas consultas cujos resultados foram unidos:

```
(1) ("MQTT"OR "Message Queuing Telemetry Transport") AND (security OR authentication OR
authorization OR encryption) AND ("Internet of Things"OR IoT)
(2) ("MQTT"OR "Message Queuing Telemetry Transport") AND (attack OR attacks OR vulnerability OR
intrusion OR privacy) AND ("Internet of Things"OR IoT)
Filtro: Years 2014-2026; Article types: Research articles.
```

String secundária (revisões), em todas as bases

```
<string principal> AND ("systematic literature"OR "systematic review"OR "literature review"OR
"survey")
```

B Extração de dados por estudo

Tabela 20. Resumo da extração de dados dos estudos incluídos.

ID	Estudo	Cat.	Contributo principal	Avaliação reportada
E01	Singh et al. [28]	C4	SMQTT e SMQTT-SN: KP/CP-ABE sobre ECC leve	Não reportada no resumo
E02	Niruntasukrat et al. [38]	C3	Autorização baseada em OAuth 1.0a adaptada a nós restritos sem interface de utilizador	Plataforma IoT real; atraso de autorização e *overhead*
E03	Rizzardi et al. [39]	C3	AUPS: gestão de chaves e aplicação de políticas sobre o MQTT; código aberto (Apache 2.0)	Protótipo de código aberto
E04	Andy et al. [6]	C1	Cenários de ataque ao MQTT sem cifra; razões para a falta de segurança nas implementações	Demonstração de ataques
E05	Calabretta et al. [31]	C3	MQTT-Auth: AugPAKE para confidencialidade e dois *tokens* (autenticação e autorização por tópico); hierarquias de tópicos	Comparação com soluções da literatura
E06	Hernández Ramos et al. [41]	C1	Enquadramento de *fuzzing* baseado em modelos para o MQTT	Resultados experimentais iniciais
E07	Dinculeană e Cheng [42]	C5	Mapeamento *Value-to-HMAC*: confidencialidade e integridade com um só mecanismo	Desempenho face a cifra simétrica
E08	Lohachab e Karambir [44]	C2	Autenticação e autorização leves entre dispositivos com ECC e MQTT	Implementação; comparação de segurança e desempenho
E09	Malina et al. [45]	C5	Três níveis de segurança: integridade, privacidade de fontes e recetores, segurança de longo prazo com autenticação mútua	Não reportada no resumo
E10	Sadio et al. [18]	C5	AEAD ChaCha20-Poly1305 fim-a-fim para MQTT e MQTT-SN	Arduino UNO; memória e tempo de execução
E11	Vaccari et al. [24]	C1	SlowITe: DoS de baixa taxa que explora a configuração do servidor pelo cliente	Serviços MQTT reais, com e sem cifra
E12	Vaccari et al. [25]	C7	MQTTset: conjunto de dados de tráfego MQTT legítimo e de ataques	Sistema de deteção por ML

ID	Estudo	Cat.	Contributo principal	Avaliação reportada
E13	Segarra et al. [7]	C6	MQT-TZ: *broker* em ARM TrustZone; TLS mútuo e cifra em duas camadas	Micro e macro *benchmarks*; cargas de uma aplicação médica
E14	Dahlmanns et al. [40]	C5	ENTRUST: segurança fim-a-fim baseada em servidor de chaves, sem alterar o protocolo	Implementação sobre MQTT
E15	Spielvogel et al. [14]	C6	O *broker* só reencaminha por ligações com o nível de segurança exigido	Protótipo; medições de *overhead*
E16	Prantl et al. [13]	C6	Impacto do TLS no MQTT: débito, estabelecimento de ligação, energia	Microcontrolador comercial; todos os níveis de QoS
E17	Van Glabbeek et al. [43]	C5	Segurança muitos-para-muitos leve integrada no MQTT	$-80\,\%$ *overhead* de comunicação e $-40\,\%$ computacional face ao MQTTS
E18	Buccafurri et al. [36]	C8	MQTT-A: anonimato de *publishers* e subscritores via *bridges*	*Brokers* em nuvem em vários países; latência e *goodput*
E19	Alotaibi et al. [29]	C7	Deteção distribuída de anomalias com H2O (melhor: XGBoost)	MSE, RMSE, erro por classe, *log loss*
E20	Javadi et al. [37]	C2	CMAP: autenticação mútua sem certificados sobre ECC	Verificação formal; Raspberry Pi com Mosquitto; NS-3